



1

2

**HARMONISED EUROPEAN STANDARD**

# HARMONISED EUROPEAN STANDARD

Draft ETSI EN 304 626 V0.0.6 (2025-09-21)

## CYBER; CRA; Essential cybersecurity requirements for Operating Systems

### CAUTION:

Exercising one of the Principles of international standardization – Openness – and taking it to a different level, ETSI is piloting informal public consultations of the vertical standards in support of the Cyber Resilience Act at a much earlier stage than it is usual in the standardization world. In this context, please keep in mind that the standard draft herein is an INTERIM DRAFT, which expectably will be subject to substantial changes before its target publication date in the second semester of 2026.

### Disclaimer

This **INTERIM DRAFT** document is provided for information and is for future development work within the ETSI Technical Committee CYBER EUSR Working Group (CYBER-EUSR) only. ETSI and its Members accept no liability for any further use/implementation of this Specification. Approved and published specifications and reports shall be obtained exclusively via the ETSI Documentation Service at <http://www.etsi.org/standards-search>

### Commenting guidelines

Your comments to improve this early draft are very welcomed. To ensure the effectiveness of your contribution, please make sure to include the following elements in your comment:

1. Clear identification of the section of the draft your comment is referring to.
2. Objective proposal to delete content, add content or substitute content.
3. Concrete contribution (exact content you suggest including in the draft as an addition to, or in substitution of, existing content).
4. Brief rationale to justify the proposal (e.g. why the suggested content should be added an/or the existing content should be deleted or substituted). Please note that comments without concrete contributions will be noted but not

acted upon by ETSI CYBER-EUSR. We trust and value your expertise and therefore expect you to take this opportunity to proactively contribute to solving the issues you find while analysing this early draft.

#### **How to comment**

To comment or provide feedback on the present interim draft please visit : <https://labs.etsi.org/rep/stan4cra/en-304-626> and submit your comments as “issues” following the guidelines provided on this site.

Alternatively, you may also send your comments to: [cybersupport@etsi.org](mailto:cybersupport@etsi.org) using the “[ETSI Commenting Format for Open Consultation.xlsx](#)” available in <https://docbox.etsi.org/CYBER/EUSR/Open>

#### **Reference**

DEN/CYBER-EUS-0012

#### **Keywords**

Cybersecurity, OS, CRA

#### **ETSI**

650 Route des Lucioles

F-06921 Sophia Antipolis Cedex - FRANCE

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - APE 7112B

Association à but non lucratif enregistrée à la

Sous-préfecture de Grasse (06) N° w061004871

#### ***Important notice***

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of

any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format on [ETSI deliver](#) repository.

Users should be aware that the present document may be revised or have its status changed, this information is available in the [Milestones listing](#).

If you find errors in the present document, please send your comments to the relevant service listed under [Committee Support Staff](#).

If you find a security vulnerability in the present document, please report it through our [Coordinated Vulnerability Disclosure \(CVD\)](#) program.

#### ***Notice of disclaimer & limitation of liability***

The information provided in the present deliverable is directed solely to professionals who have the appropriate degree of experience to understand and interpret its content in accordance with generally accepted engineering or other professional standard and applicable regulations.

No recommendation as to products and services or vendors is made or should be implied.

No representation or warranty is made that this deliverable is technically accurate or sufficient or conforms to any law and/or governmental rule and/or regulation and further, no representation or warranty is made of merchantability or fitness for any particular purpose or against infringement of intellectual property rights.

In no event shall ETSI be held liable for loss of profits or any other incidental or consequential damages.

Any software contained in this deliverable is provided “AS IS” with no warranties, express or implied, including but not limited to, the warranties of merchantability, fitness for a particular purpose and non-infringement of intellectual property rights and ETSI shall not be held liable in any event for any damages whatsoever (including, without limitation, damages for loss of profits, business interruption, loss of information, or any other pecuniary loss) arising out of or related to the use of or inability to use the software.

#### ***Copyright Notification***

No part may be reproduced or utilized in any form or by any means, electronic or mechanical, including photocopying and microfilm except as authorized by written permission of ETSI. The content of the PDF version shall not be modified without the written authorization of ETSI. The copyright and the foregoing restriction extend to reproduction in all media.

© ETSI 2025.

All rights reserved.

# Contents

|     |                                                                                  |
|-----|----------------------------------------------------------------------------------|
| 94  |                                                                                  |
| 95  | <a href="#">HARMONISED EUROPEAN STANDARD</a>                                     |
| 96  | <a href="#">Intellectual Property Rights</a>                                     |
| 97  | <a href="#">Essential patents</a>                                                |
| 98  | <a href="#">Trademarks</a>                                                       |
| 99  | <a href="#">Foreword</a>                                                         |
| 100 | <a href="#">Modal verbs terminology</a>                                          |
| 101 | <a href="#">Executive summary</a>                                                |
| 102 | <a href="#">Introduction</a>                                                     |
| 103 | <a href="#">1 Scope</a>                                                          |
| 104 | <a href="#">1.1 General</a>                                                      |
| 105 | <a href="#">1.2 Products in scope</a>                                            |
| 106 | <a href="#">1.2.1 Elements of operating systems that are in scope</a>            |
| 107 | <a href="#">1.3 Products not in scope</a>                                        |
| 108 | <a href="#">2 References</a>                                                     |
| 109 | <a href="#">2.1 Normative references</a>                                         |
| 110 | <a href="#">2.2 Informative references</a>                                       |
| 111 | <a href="#">3 Definition of terms, symbols and abbreviations</a>                 |
| 112 | <a href="#">3.1 Terms</a>                                                        |
| 113 | <a href="#">3.2 Abbreviations</a>                                                |
| 114 | <a href="#">4 Product context</a>                                                |
| 115 | <a href="#">4.1 General</a>                                                      |
| 116 | <a href="#">4.2 Out of scope use/environments</a>                                |
| 117 | <a href="#">4.3 Product overview and architecture</a>                            |
| 118 | <a href="#">4.3.1 Overview</a>                                                   |
| 119 | <a href="#">4.3.2 Operating system security functions</a>                        |
| 120 | <a href="#">4.3.3 High-level operating system architectures</a>                  |
| 121 | <a href="#">4.3.3 Access control mechanisms</a>                                  |
| 122 | <a href="#">4.3.4 Resource management</a>                                        |
| 123 | <a href="#">4.3.5 Scheduling</a>                                                 |
| 124 | <a href="#">4.4 Use Cases</a>                                                    |
| 125 | <a href="#">4.5 Risk factors</a>                                                 |
| 126 | <a href="#">4.5.1 List of risk factors</a>                                       |
| 127 | <a href="#">4.5.1.1 Number of Users</a>                                          |
| 128 | <a href="#">4.5.1.2 User Concurrency</a>                                         |
| 129 | <a href="#">4.5.1.3 Data Storage</a>                                             |
| 130 | <a href="#">4.5.1.4 Collection or sharing of sensitive personal data</a>         |
| 131 | <a href="#">4.5.1.5 Physical Access by Threat Actors to the Device</a>           |
| 132 | <a href="#">4.5.1.6 Probability of Loss of the Device</a>                        |
| 133 | <a href="#">4.5.1.7 Hardware Modifiability by End Users</a>                      |
| 134 | <a href="#">4.5.1.8 Software Modifiability by End Users</a>                      |
| 135 | <a href="#">4.5.1.9 Untrusted Peripheral Devices</a>                             |
| 136 | <a href="#">4.5.1.10 Access To The Internet</a>                                  |
| 137 | <a href="#">4.5.1.11 Accessed From Untrusted Networks Including The Internet</a> |
| 138 | <a href="#">4.5.1.12 Configurability</a>                                         |
| 139 | <a href="#">4.5.2 Mapping of Use Cases to Risk Factors</a>                       |
| 140 | <a href="#">4.6 Risk Tolerance</a>                                               |
| 141 | <a href="#">4.7 Essential functions</a>                                          |
| 142 | <a href="#">4.8 Operational Environment</a>                                      |
| 143 | <a href="#">4.9 Users</a>                                                        |
| 144 | <a href="#">4.10 Distribution of security functions</a>                          |
| 145 | <a href="#">4.10.1 General</a>                                                   |
| 146 | <a href="#">4.10.2 Security functions provided outside the product</a>           |
| 147 | <a href="#">4.10.3 Security functions provided to other components</a>           |
| 148 | <a href="#">5 Requirements specifications</a>                                    |
| 149 | <a href="#">5.1 Notes on the structure of requirements</a>                       |
| 150 | <a href="#">5.2 Technical security requirements specifications</a>               |
| 151 | <a href="#">5.2.1 General</a>                                                    |
| 152 | <a href="#">5.2.X TR-MISO: Memory isolation</a>                                  |
| 153 | <a href="#">5.2.X.1 Threat description</a>                                       |

|     |                                                                                                           |
|-----|-----------------------------------------------------------------------------------------------------------|
| 154 | <a href="#"><u>5.2.X.x MI-SSCA: Static source code analysis for memory protection</u></a>                 |
| 155 | <a href="#"><u>5.2.X.x MI-MMUP: Memory protection using MMU</u></a>                                       |
| 156 | <a href="#"><u>5.2.X TR-OOBM: Out-of-bounds memory access prevention or mitigation</u></a>                |
| 157 | <a href="#"><u>5.2.X.1 Threat description</u></a>                                                         |
| 158 | <a href="#"><u>5.2.X.x MI-KSED: Kernel stack exhaustion detection</u></a>                                 |
| 159 | <a href="#"><u>5.2.X.x MI-KSBO: Kernel stack linear buffer overflow detection</u></a>                     |
| 160 | <a href="#"><u>5.2.X.x MI-KABC: Kernel array bounds checking</u></a>                                      |
| 161 | <a href="#"><u>5.2.X. MI-KHLO: Kernel heap linear overflow detection</u></a>                              |
| 162 | <a href="#"><u>5.2.X. MI-KUFW: Kernel heap user-after-free write prevention</u></a>                       |
| 163 | <a href="#"><u>5.2.X. MI-KUFR: Kernel heap user-after-free read prevention</u></a>                        |
| 164 | <a href="#"><u>5.2.X. MI-KHFC: Kernel heap free checking</u></a>                                          |
| 165 | <a href="#"><u>5.2.X. MI-KSMZ: Kernel stack memory zeroing</u></a>                                        |
| 166 | <a href="#"><u>5.2.X. MI-KHMO: Kernel heap memory zeroing</u></a>                                         |
| 167 | <a href="#"><u>5.2.X. MI-KLLP: Kernel linked list protection</u></a>                                      |
| 168 | <a href="#"><u>5.2.X. MI-KPXM: Prevent execution of non-kernel code memory</u></a>                        |
| 169 | <a href="#"><u>5.2.X. MI-KPWM: Prevent writes to kernel code and read-only data memory</u></a>            |
| 170 | <a href="#"><u>5.2.X. MI-KPUM: Prevent unintentional kernel access to unprivileged memory</u></a>         |
| 171 | <a href="#"><u>5.2.X. MI-KRCP: Kernel reference counter protection</u></a>                                |
| 172 | <a href="#"><u>5.2.X.x MI-KFCI: Kernel forward control flow integrity</u></a>                             |
| 173 | <a href="#"><u>5.2.X.x MI-XXXX: Memory protection using Pointer Authentication Codes</u></a>              |
| 174 | <a href="#"><u>5.2.X.x MI-XXXX: Memory protection using hardware memory tagging</u></a>                   |
| 175 | <a href="#"><u>5.2.X.x MI-XXXX: Memory protection using enhanced hardware memory tagging</u></a>          |
| 176 | <a href="#"><u>5.2.X TR-LSRE: Logging of security-relevant events</u></a>                                 |
| 177 | <a href="#"><u>5.2.X.1 Threat description</u></a>                                                         |
| 178 | <a href="#"><u>5.2.X.x MI-LLOG: Local logging</u></a>                                                     |
| 179 | <a href="#"><u>5.2.X.x MI-RLOG: Remote logging</u></a>                                                    |
| 180 | <a href="#"><u>5.2.X TR-LLTP: Local log tamper prevention</u></a>                                         |
| 181 | <a href="#"><u>5.2.X.1 Threat description</u></a>                                                         |
| 182 | <a href="#"><u>5.2.X.x MI-LLGA: Local log file only editable by privileged users</u></a>                  |
| 183 | <a href="#"><u>5.2.X TR-RLTP: Remote log tamper prevention</u></a>                                        |
| 184 | <a href="#"><u>5.2.X.1 Threat description</u></a>                                                         |
| 185 | <a href="#"><u>5.2.X.x MI-RLSA: Remote log server authentication</u></a>                                  |
| 186 | <a href="#"><u>5.2.X.x MI-RLET: Encrypt log message stream with tamper-evident protocol</u></a>           |
| 187 | <a href="#"><u>5.2.X TR-PCFG: Prevent unauthorized changes of security-relevant configuration</u></a>     |
| 188 | <a href="#"><u>5.2.X.1 Threat description</u></a>                                                         |
| 189 | <a href="#"><u>5.2.X.x MI-CFGA: Security-relevant configuration not editable by unauthorized user</u></a> |
| 190 | <a href="#"><u>5.2.X TR-XXXX:</u></a>                                                                     |
| 191 | <a href="#"><u>5.2.X.1 Threat description</u></a>                                                         |
| 192 | <a href="#"><u>5.2.X.x MI-XXXX:</u></a>                                                                   |
| 193 | <a href="#"><u>NOTES</u></a>                                                                              |
| 194 | <a href="#"><u>5.3 Risk Mitigation Sets</u></a>                                                           |
| 195 | <a href="#"><u>6 Security Profiles</u></a>                                                                |
| 196 | <a href="#"><u>6.1 General</u></a>                                                                        |
| 197 | <a href="#"><u>6.2 Details of Security Profiles</u></a>                                                   |
| 198 | <a href="#"><u>6.2.1 SP-IoT-1 :: RT-HIGH</u></a>                                                          |
| 199 | <a href="#"><u>6.2.2 SP-IoT-2 :: RT-HIGH</u></a>                                                          |
| 200 | <a href="#"><u>6.2.3 SP-IoT-3 :: RT-HIGH</u></a>                                                          |
| 201 | <a href="#"><u>6.2.4 SP-OT-1 :: RT-???</u></a>                                                            |
| 202 | <a href="#"><u>6.2.5 SP-OT-2 :: RT-???</u></a>                                                            |
| 203 | <a href="#"><u>6.2.6 SP-MOB-1 :: RT-???</u></a>                                                           |
| 204 | <a href="#"><u>6.2.7 SP-WE-1 :: RT-???</u></a>                                                            |
| 205 | <a href="#"><u>6.2.8 SP-ST-1 :: RT-???</u></a>                                                            |
| 206 | <a href="#"><u>6.2.9 SP-PC-1 :: RT-LOW</u></a>                                                            |
| 207 | <a href="#"><u>6.2.10 SP-PC-2 :: RT-???</u></a>                                                           |
| 208 | <a href="#"><u>6.2.11 SP-LA-1 :: RT-???</u></a>                                                           |
| 209 | <a href="#"><u>6.2.12 SP-LA-2 :: RT-???</u></a>                                                           |
| 210 | <a href="#"><u>6.2.13 SP-PS-1 :: RT-???</u></a>                                                           |
| 211 | <a href="#"><u>6.2.14 SP-SE-1 :: RT-???</u></a>                                                           |
| 212 | <a href="#"><u>6.2.15 SP-SE-2 :: RT-???</u></a>                                                           |
| 213 | <a href="#"><u>6.2.16 SP-SE-3 :: RT-???</u></a>                                                           |
| 214 | <a href="#"><u>6.2.17 SP-IF-1 :: RT-???</u></a>                                                           |
| 215 | <a href="#"><u>6.2.18 SP-IF-2 :: RT-???</u></a>                                                           |

|     |                                                                                                                                 |
|-----|---------------------------------------------------------------------------------------------------------------------------------|
| 216 | <a href="#"><u>6.2.19 SP-IF-3 :: RT-???</u></a>                                                                                 |
| 217 | <a href="#"><u>6.2.20 SP-FI-1 :: RT-???</u></a>                                                                                 |
| 218 | <a href="#"><u>6.2.21 SP-FI-2 :: RT-???</u></a>                                                                                 |
| 219 | <a href="#"><u>6.3 Mapping of Security Profile to Risk Tolerance</u></a>                                                        |
| 220 | <a href="#"><u>6.4 Mapping of Security Profile to Risk Mitigation</u></a>                                                       |
| 221 | <a href="#"><u>Annex A (informative): Relationship between the present document and any related ETSI standards (if any)</u></a> |
| 222 | <a href="#"><u>Annex A (informative): Mapping between the present document and CRA requirements</u></a>                         |
| 223 | <a href="#"><u>Annex B (informative): Relationship between the present document and any related ETSI standards (if any)</u></a> |
| 224 | <a href="#"><u>Annex C (informative): Risk identification and assessment methodology</u></a>                                    |
| 225 | <a href="#"><u>C.1 Assets</u></a>                                                                                               |
| 226 | <a href="#"><u>C.1.1 Data</u></a>                                                                                               |
| 227 | <a href="#"><u>C.1.2 Product functions</u></a>                                                                                  |
| 228 | <a href="#"><u>C.2 Threats</u></a>                                                                                              |
| 229 | <a href="#"><u>C.3 Assumptions</u></a>                                                                                          |
| 230 | <a href="#"><u>C.4 Risk assessments of threats</u></a>                                                                          |
| 231 | <a href="#"><u>Annex D (informative): Risk evaluation guidance</u></a>                                                          |
| 232 | <a href="#"><u>D.1 Mapping of risks to requirements</u></a>                                                                     |
| 233 | <a href="#"><u>D.2 Risks not treated by the requirements</u></a>                                                                |
| 234 | <a href="#"><u>D.3 Risk acceptance criteria</u></a>                                                                             |
| 235 | <a href="#"><u>D.4 Residual risks</u></a>                                                                                       |
| 236 | <a href="#"><u>Annex E: Notes</u></a>                                                                                           |
| 237 | <a href="#"><u>Annex &lt;L+3&gt; (informative): Bibliography</u></a>                                                            |
| 238 | <a href="#"><u>Annex &lt;L+4&gt; (informative): Change history</u></a>                                                          |
| 239 | <a href="#"><u>History</u></a>                                                                                                  |

---

## Intellectual Property Rights

### Essential patents

IPRs essential or potentially essential to normative deliverables may have been declared to ETSI. The declarations pertaining to these essential IPRs, if any, are publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: *“Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified to ETSI in respect of ETSI standards”*, which is available from the ETSI Secretariat. Latest updates are available on the [ETSI IPR online database](#).

Pursuant to the ETSI Directives including the ETSI IPR Policy, no investigation regarding the essentiality of IPRs, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become, essential to the present document.

### Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organizations associated with those trademarks.

**DECT™**, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members. **3GPP™**, **LTE™** and **5G™** logo are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organizational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners. **GSM®** and the GSM logo are trademarks registered and owned by the GSM Association.



## Foreword

### DRAFT FOREWORD - DO NOT CONSIDER THE CONTENT

This draft Harmonised European Standard (EN) has been produced by ETSI Technical Committee Cyber Working Group for EUSR (CYBER-EUSR), and is now submitted for the combined Public Enquiry and Vote phase of the ETSI Standardisation Request deliverable Approval Procedure (SRdAP).

The present document has been prepared under the Commission's standardisation request C(2025) 618 final to provide one voluntary means of conforming to the requirements of Regulation (EU) No 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

#### Transposition table

The Harmonised Standard shall have appropriate transposition periods specified. A Harmonised Standard confers presumption of conformity when it has been published in the Official Journal of the European Union (OJEU) and transposed by a member state.

The Technical Body may propose different dates to the default ones (3, 6, 18). Technical Bodies who wish to propose different dates are advised to indicate this clearly in the approved committee draft.

| Proposed national transposition dates                          |                                 |
|----------------------------------------------------------------|---------------------------------|
| Date of latest announcement of this EN (doa):                  | 3 months after ETSI publication |
| Date of latest publication of new National Standard            |                                 |
| or endorsement of this EN (dop/e):                             | 6 months after doa              |
| Date of withdrawal of any conflicting National Standard (dow): | 18 months after doa             |

The Technical Body should advise the ETSI Secretariat if the above default national transposition dates are inappropriate for the particular standard.

284

---

## Modal verbs terminology

285

In the present document “**shall**”, “**shall not**”, “**should**”, “**should not**”, “**may**”, “**need not**”, “**will**”, “**will not**”, “**can**”

286

and “**cannot**” are to be interpreted as described in clause 3.2 of the [ETSI Drafting Rules](#) (Verbal forms for the expression of provisions).

287

288

“**must**” and “**must not**” are **NOT** allowed in ETSI deliverables except when used in direct citation.

---

## Executive summary

290

---

## Introduction

291

292

293

The present document is a European harmonised standard that defines cybersecurity requirements for products whose primary purpose is providing an operating system. Demonstrating compliance with this standard is not necessary, but doing so provides a presumption of conformity with Regulation (EU) 2024/2847, the Cyber Resilience Act.

294

295

296

This standard does not apply to products that contain an operating system or are part of an operating system if the core purpose of the product is not that of an operating system. However, it may be useful as one part of the process of demonstrating compliance for a product containing or interacting with an operating system.

# 1 Scope

## 1.1 General

The present document describes how to demonstrate compliance with requirements in the EU Regulation 2024/2847 under the conditions identified in Annex <L> of operating systems, within the context described in section 4, Product Context.

## 1.2 Products in scope

Products in scope are products whose core function and intended or reasonably foreseeable use or misuse is as an operating system. Operating systems include software products with digital elements that provide an abstract interface of the underlying hardware and control the execution of software, and that may provide services such as computing resource management and configuration, scheduling, input-output control, managing data, and providing an interface through which applications interact with system resources and peripherals. The underlying hardware may be virtualized to some degree, as when an operating system is running on a hypervisor.

This category includes but is not limited to:

- general purpose operating systems
- personal computing operating systems
- mobile phone operating systems
- server operating systems
- real-time operating systems
- embedded operating systems
- special purpose operating systems

Many products contain multiple operating systems which can affect the security functions of other operating system(s) in the product. For example, a Baseboard Management Controllers (BMC) contains an operating system that can manage most or all of the hardware managed by the main system operating system. Radiofrequency transmission devices often have an embedded real-time operating system and the ability to read or write to system memory or trigger interrupts.

### 1.2.1 Elements of operating systems that are in scope

The scope is limited to the security-relevant parts of the operating system. This includes any element capable of modifying elements that control the security of the system, as well as elements that provide security functionality.

Security-relevant parts of the operating system include but are not limited to:

- the kernel
- device drivers if supplied with the operating system
- libraries used to provide security-relevant services
- authentication services
- processes running with elevated privileges
- software installation and update system
- logging and monitoring
- configuration of security-relevant items

- security-relevant system default configuration

### 1.3 Products not in scope

Detailed list of things whose scope might be confusing, including parts of a system which are often included when the terms in the “in scope” section are used in general conversation. Reference the “Product Context” section again to remind the reader what operational environments are in scope.

This standard does not cover products in use in contexts other than those identified in Annex <L>.

This standard does not cover parts of the operating system that are not security-relevant.

This standard does not cover:

- Hypervisors or containers
- Boot managers or boot loaders
- Hardware, microcode, or special purpose device firmware
- Device drivers not shipped with the operating system, including those stored on devices
- Usermode “operating systems,” applications which emulate parts of an operating system on top of another operating system’s user API

While hypervisors abstract the underlying hardware and may provide services similar to operating systems such as resource management and scheduling, the set of services they supply to clients are far more limited than those of an operating system. Hypervisors provide clients an emulated hardware platform rather than a set of abstract operating system services.

Containers are a set of process isolation features provided by operating systems. They are an operating system feature, not an operating system.

Usermode “operating systems” are applications simulating an operating system in an application, implemented on top of another operating system’s user API. These applications are often used to learn about, develop, or emulate the parts of operating systems that do not directly interface with underlying hardware. They do not and cannot provide the core functions of an operating system as defined for the purposes of this standard.

Boot managers have the primary purpose of initializing the hardware after power on or reset with the goal of choosing, loading, and/or transferring execution to an operating system or other program. While many boot managers provide some or all of the services of an operating system (or are literally operating systems adapted for use as a boot manager), they are designed and intended primarily to transfer control to an operating system or other program, rather than continuously operate and provide services.

FIXME: make this more specific. Firmware running on a device is an operating system if its core function is to abstract the hardware platform and control the execution of software that uses services it provides. Otherwise it is special purpose device-specific firmware.

Device drivers are generally included in the security-relevant parts of an operating system. However, the manufacturer of the operating system is only responsible for device drivers included in the operating system.

FIXME diagram(s) showing relationship to hypervisors, containers, boot managers, IAM, network interfaces, antivirus, hardware, and software.

## 2 References

### 2.1 Normative references

**In Harmonised Standards these references shall be specific** (identified by date of publication and/or edition number or version number) **publicly available and in English, except in exceptional circumstances making sure that impacts have been evaluated and explanations have been given on how any negative implications should be avoided**. See clauses 2.10.1 and 8.4 of the [EDRs](#) and the communiqué on “[References in ETSI Deliverables](#)”.

Guidance for selecting normative references in harmonised standards is given in clause 2.8.3 of the Vademecum on European standardisation. Please **systematically consult with your Technical Officer** for the latest guidance on normative references other than to ENs, ISO/IEC standards, notably to prevent the risk of non-acceptance.

**Legal acts can never be used as normative references.**

It is recommended that the number of references be limited to the minimum needed for the implementation/application of the ETSI Deliverables. References not directly concerned with the implementation/application/understanding of the ETSI Deliverable shall be listed in the Bibliography annex.

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

Referenced documents which are not found to be publicly available in the expected location might be found in the [ETSI docbox](#).

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents are necessary for the application of the present document.

- [1] <Standard Organization acronym> <document number> (<version number>): “<Title>”.

### 2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or nonspecific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents may be useful in implementing an ETSI deliverable or add to the reader’s understanding but are not required for conformance to the present document.

- [i.1] BSI CC-PP-0067 “Operating System Protection Profile”.
- [i.number] ETSI TS 103 732 “Consumer Mobile Device Protection Profile”.
- [i.number] <Standard Organization acronym> <document number> (<version number>): “<Title>”.

## 3 Definition of terms, symbols and abbreviations

**NOTE:** Existing ETSI terms and abbreviations can be searched here:  
<https://webapp.etsi.org/Teddi/>

### 3.1 Terms

This section provides terms and definitions based on CEN/CLC JTC13 WG09's work on terms and definitions, terms and definitions provided by ETSI EN 303 645/TS 103 701 and by CEN/CLC EN 18031 series, and informed by terms used in the Common Criteria and the NIAP Operating System Protection Plan guide.

For the purposes of the present document, the following terms apply:

**Operating System (OS):** Software products with digital elements that provide an abstract interface of the underlying hardware and control the execution of software, and that may provide services such as computing resource management and configuration, scheduling, input-output control, managing data, and providing an interface through which applications interact with system resources and peripherals. This category includes but is not limited to real-time operating systems, general-purpose and special-purpose operating systems.

**General Purpose Operating System:** A class of operating system designed to support a wide variety of workloads consisting of concurrent applications or services. Typical characteristics of this category include support for third-party applications, support for multiple users, and security separation between users and their respective resources. General Purpose Operating Systems lack the operational constraints which define Special Purpose Operating Systems and Real Time Operating System (RTOS) that are typically used in routers, switches, and embedded devices.

**Application Programming Interface (API):** A specification of routines, data structures, object classes, and variables that allows an application to make use of services provided by another software component, such as a library. APIs are often provided for a set of libraries included with the platform.

**System Call Interface:** A specification for the API between the application layer and the kernel or system layer.

**Input/Output:** The process or function for passing data to or from a given process over a specific interface. Such I/O interfaces include, but are not limited to, serial ports, network ports, long-term storage devices including hard drives and flash drives, as well as human-interface ports such as display and audio devices.

**Common Criteria (CC):** Common Criteria for Information Technology Security Evaluation (International Standard ISO/IEC 15408).

**Administrator:** An administrator is responsible for management activities, including setting policies that are applied by the enterprise on the operating system. This administrator could be acting remotely through a management server, from which the system receives configuration policies. An administrator can enforce settings on the system which cannot be overridden by non-administrator users.

**User:** A user is subject to configuration policies applied to the operating system by administrators. On some systems under certain configurations, a normal user can temporarily elevate privileges to that of an administrator. At that time, such a user should be considered an administrator.

**Application:** Software that runs on a platform and performs tasks on behalf of the user or owner of the platform, as well as its supporting documentation.

**Credential:** Data that establishes the identity of a user, e.g. a cryptographic key or password.

**Personally Identifiable Information (PII):** Any information about an individual maintained by an agency, including, but not limited to, education, financial transactions, medical history, and criminal or employment history and information which can be used to distinguish or trace an individual's identity, such as their name, government-issued identity numbers, date and place of birth, biometric records, etc., including any other personal information which is linked or linkable to an individual.

**Sensitive Data:** Sensitive data may include all user or enterprise data or may be specific application data such as PII, emails, messaging, documents, calendar items, and contacts. Sensitive data must minimally include credentials and keys.

**Data Execution Prevention:** An anti-exploitation feature of modern operating systems executing on modern computer hardware, which enforces a non-execute permission on pages of memory that are not code. This prevents pages of



memory from containing both data and instructions, which makes it more difficult for an attacker to introduce and execute code.

FIXME add “non-writable executable memory” i.e. W^X

FIXME add “Attack Surface” i.e. reduce the attack surface of the system call interface...

FIXME add “Principle of Least Privilege”

FIXME add “Threat Actor”

**Credential:** Data that establishes the identity of a user, e.g. a cryptographic key or password.

**Address Space Layout Randomization (ASLR):** An anti-exploitation feature which loads memory mappings into unpredictable locations. ASLR makes it more difficult for an attacker to redirect control to code that they have introduced into the address space of a process.

**Common Weakness Enumeration (CWE):** A community-developed list of software and hardware weaknesses that can become vulnerabilities. <https://cwe.mitre.org/>

**Elevated Privilege:** A level of access that allows accessing or changing security-relevant configuration, data, or functions on a system.

**Command Shell:** A text-based interface allowing execution of system programs.

**Process Isolation:** Techniques to prevent processes from accessing or changing each other’s state.

## 3.2 Abbreviations

For the purposes of the present document, the following abbreviations apply:

| Abbreviation | Description            |
|--------------|------------------------|
| OS           | Operating system       |
| MMU          | Memory Management unit |
| IO           | Input/Output           |

For the purposes of the present document’s risk analysis, the following abbreviations apply:

| Abbreviation | Description      |
|--------------|------------------|
| UC           | Use Case         |
| SP           | Security Profile |
| RF           | Risk Factor      |
| RT           | Risk Tolerance   |

## 4 Product context

### 4.1 General

NOTE: This section's structure is built upon CEN/CLC JTC13 PT01's deliverable and might require restructuring based on its progress.

### 4.2 Out of scope use/environments

For the convenience of the developers of these standards, the following list is temporarily included and will be removed before publication:

The types of product with digital elements listed in the section do not fall within the scope of the Regulation (EU) 2024/2847 (Cyber Resilience Act) [i.1], and are not covered by this standard:

1. Services, except for the remote data processing solutions for a covered product as defined in CRA recitals 11-12; article 3, 2 [i.1]
2. Products specifically designed or procured for national security and defence purpose as defined in CRA recitals 14 and 26; article 2, 7-8 [i.1]
3. Products developed for or used exclusively for internal use by public administration as defined in CRA recital 16; article 5, 2 [i.1]
4. Non-commercial free and open source software as defined in CRA recitals 17-21; article 13, 5 [i.1]
5. Medical Devices and Software as defined in CRA recital 25; article 2, 2 [a-b] [i.1]
6. Vehicles, including aviation and marine equipment as defined in CRA recital 27; article 2, 2.c "vehicles"; recital 27; article 2, 3 "aviation"; article 2, 4 "marine equipment" [i.1]
7. Spare and used parts as defined in CRA recital 29; article 2, 6 [i.1]
8. Refurbished, repaired, and upgraded products that have not been substantially modified as defined in recitals 39 - 42 [i.1]

The following types of products have reduced or varied requirements under Regulation (EU) 2024/2847 (Cyber Resilience Act) [i.1] and can only be partially covered by this standard:

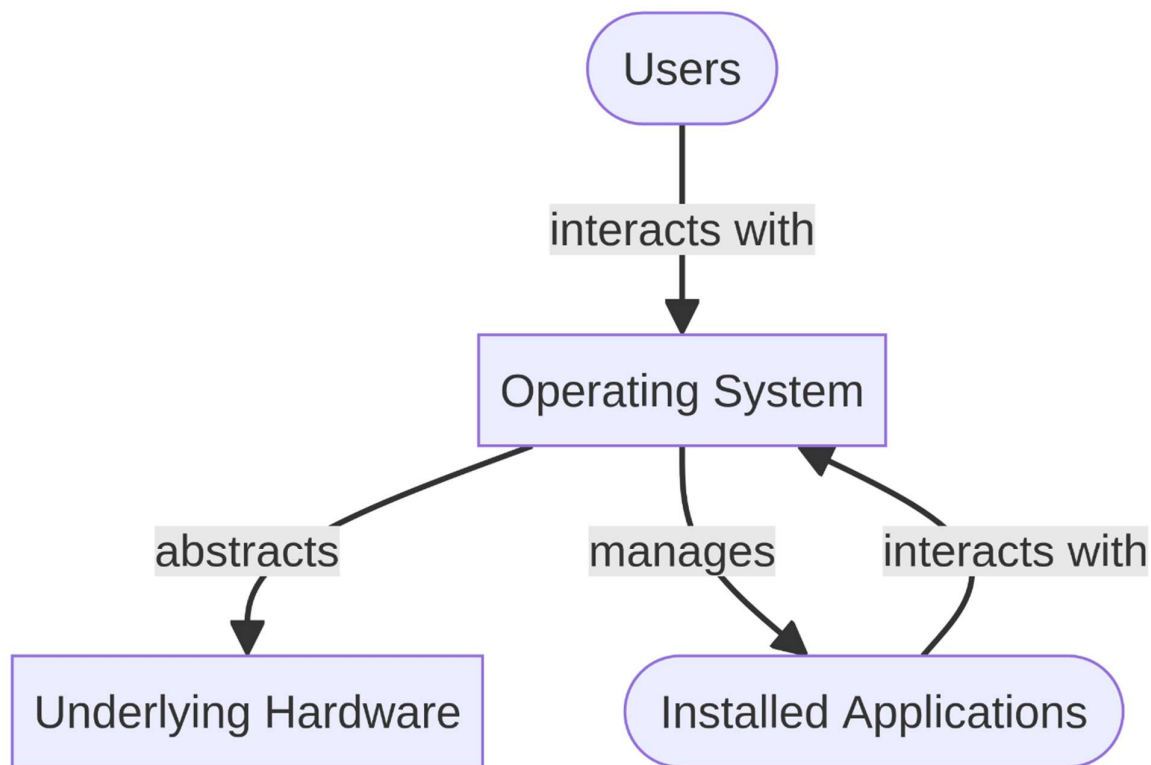
1. High Risk AI as defined in CRA recital 51; article 12 [i.1]
2. Testing and unfinished versions as defined in recital 37; Article 4, 2-3 [i.1]
3. Products Placed on the Market Prior to December 11, 2027 as defined in CRA article 69 [i.1]

Out of scope use cases and environments include those explicitly carved out by the Regulation (EU) 2024/2847 (Cyber Resilience Act) [i.1], and are not covered by this standard.

### 4.3 Product overview and architecture

#### 4.3.1 Overview

An operating system abstracts the hardware, allocates resources, and provides services to itself and any other software on the system. It often serves as a central organizing authority that controls access to system resources by various pieces of software, dividing up available resources among the applications and its own subsystems to meet implicit or explicit goals or constraints. An operating system often uses a large part of the resources of the system it runs on, but in return it simplifies the development and deployment of the overall system.



**Temporary architecture diagram**

FIXME GitLab pipeline doesn't work with mermaid

Operating system architecture is quite varied, depending on factors such as the intended use case, the underlying platform, and the design philosophy of the developers. This overview will focus on the elements of operating system architecture that have a significant impact on the security functions and risk mitigations of an operating system.

### 4.3.2 Operating system security functions

To oversimplify, the security of an operating system depends on appropriately controlling the instructions to be executed on the processors on the system under its control. Instruction flow is dependent on the text of the executable, any data it accesses, and any hardware that has the ability to change either data or which instructions are being executed. For example, a network interface adapter can write to system memory, altering the data and changing the execution of any code that results in it. A USB controller can raise an interrupt which can cause the interrupt controller to force the CPU to switch to executing interrupt handling code, altering the instruction flow.

A fundamental building block of operating system is privileges. Privileges which control which system resources or functions that program can access. The operating system grants a defined set of privileges to itself, its subsystems, and any other executing software program.

Generally privileges are enforced using hardware features such as a memory management unit and processor-defined privilege levels. If the hardware does not provide these features, the operating system may use a best effort system, such as relying on the compiler to generate code that is less likely to accidentally interfere with the functions of the operating system or other parts of the system. A best-effort approach is only acceptable in low-risk, low-impact use cases where all elements and users of the systems can be trusted to not deliberately attempt to compromise the system.

### 4.3.3 High-level operating system architectures

Operating systems architecture varies in many ways. Some of the most security-relevant ways include:

- Proportion of operating system code running in different protection domains
- Whether applications run in a separate protection domain from the operating system
- Method of communication between protection domains

Each of these design variations makes different tradeoffs between security, performance, and ease of implementation.

Reducing the proportion of code running at the highest privilege level improves security by reducing the amount of vulnerable code, at the cost of lower performance due to the need to switch between privilege domains more often. Applications running in a separate protection domain dramatically reduces the amount of vulnerable code on most systems, again at the cost of lower performance when switching between protection domains. The method of communication between protection domains is generally a tradeoff between the speed of shared memory and the safety of checking and copying specific data (e.g., directly reading/writing a region of shared memory vs. using a system call or interprocess communication interface).

A few of the more common operating systems architectures include:

**Monolithic kernel:** The operating system kernel is one executable running at the highest processor privilege level in one memory domain, providing the majority of system-wide services. Applications are in separate memory domains and have a lesser privilege level. Applications request services and resources via system calls. Often a monolithic kernel supports modules, which allows parts of the kernel to be added or removed at run-time, but they are usually sharing the same memory domain and privilege level.

**Microkernel:** The operating system kernel running at the highest processor privilege level provides a minimal set of resource allocation services, while many of the operating systems services are provided by separate executables with lower privileges.

**Hybrid kernel:** A mix of microkernel and monolithic kernel, where some operating systems services are provided in the central kernel and some are provided by applications. Subsystems that do not need to be high performance and are a frequent source of vulnerabilities are often moved into applications, such as printer drivers or file systems with complex features and/or low performance requirements.

**Exokernel:** The operating system does not abstract the resources of the system, it only manages resource allocation between different applications.

**Unikernel:** The operating system and the application are effectively a single executable. Often this is described as a library operating system: a set of library routines that an application can include and effectively become the operating system.

Note that in many cases, system libraries and applications are necessary for the function of the operating system, and are included in the security-relevant parts of an operating system. Some examples include the init process, userspace helpers to set up or access USB devices, authentication software, and libraries that wrap or simplify the process of making system calls.

### 4.3.3 Access control mechanisms

Operating systems control access to resources in different ways, including:

**Access control lists:** Each resource has a list of users or processes that are allowed to access it.

**Role-based access control:** Users are assigned one or more roles, and roles have permissions associated with them.

**Capabilities:** Access to a resource is linked to a token which can be passed between processes.

### 4.3.4 Resource management

Operating systems often allocate system resources among different applications or threads, including processor time, memory, storage, file descriptors, and process table entries. Operating systems may implement limits on the number or proportion of specific resources that an application or thread may use, and may group these limits by user, process, process group, or other mechanism.

### 4.3.5 Scheduling

Operating systems may provide voluntary or involuntary switching between different threads. Some common models include:

**Cooperative scheduling:** Each thread executes on a process as long as it likes until it voluntarily yields the processor to another thread.

**Preemptive scheduling:** Each thread can be involuntarily halted and replaced by a different thread, as well as voluntarily yielding the CPU.

The operating system can choose which thread to schedule based on factors such as:

- Time spent executing during a previous time period
- Time since the thread was first marked runnable
- Explicit priorities associated with each thread
- Type of thread (kernel or application)
- Resource limits
- Performance considerations

## 4.4 Use Cases

*The following use cases are provided to assist manufacturers in selecting risk factors and security levels. This is not intended to be an exhaustive or complete list of all possible use cases.*

**TODO: update the formatting of this list to match RF and SP lists and add numbered headings**

- **UC-LR** An operating system for learning and research
  - is not used for any purpose beyond learning and research
  - does not store any sensitive or useful data
  - security is provided entirely by the environment
  - is highly modified by the user
- **UC-IoT-1** A non-internet-connected device such as a bluetooth speaker
  - does not store any user-specific data
  - has no means to connect directly to the internet
  - not intended to support hardware, software, or operating system changes
- **UC-IoT-2** An internet-enabled power switch
  - connects to a central service, operated by the device manufacturer, for remote data processing
  - stores account information to authenticate to WiFi and to cloud service provider
  - has a minimalistic interface, such as a single button for pairing and a reset button
  - does not have accessible I/O ports
- **UC-IoT-3** An internet-connected “smart home” device, such as a thermostat, fridge, or alarm system
  - connects to a central service, operated by the device manufacturer, for remote data process
  - stores account information to authenticate to WiFi and to cloud service provider

- 616 ○ does not support arbitrary file storage or end-user operating system configuration changes
- 617 ○ does not have accessible I/O ports
- 618 ○ may display personalized information, such as location-specific weather forecast
- 619 ○ serviced by trained professionals who do not modify software or hardware outside of manufacturer
- 620 specifications
- 621 • **UC-OT-1** A consumer-grade home wireless router
  - 622 ○ stores account information for authentication with ISP
  - 623 ○ not intended for end-user hardware or software modification
  - 624 ○ is exposed to the open internet
- 625 • **UC-OT-2** A business-grade remote door locking system
  - 626 ○ does not store any user data
  - 627 ○ not intended for hardware or software modification
  - 628 ○ is not exposed to the open internet, and is only connected to trusted networks
  - 629 ○ only serviced by professionals
  - 630 ○ does not have accessible I/O ports
  - 631 ○ hardware likely contains tamper-evident signals which operating system can rely on
- 632 • **UC-MOB-1** A personal smart phone
  - 633 ○ stores highly sensitive personal information
  - 634 ○ large number of sensors allow mass collection of sensitive personal data
  - 635 ○ size and cost make it a common target of theft
  - 636 ○ device usage is not limited to trusted locations and loss is foreseeable
  - 637 ○ hardware and operating system configuration not intended for modification by users
  - 638 ○ end-users frequently install software of uncertain provenance
  - 639 ○ device frequently connects to untrusted networks
  - 640 ○ device frequently collects user's location at all times
  - 641 ○ device is often always on and always connected
- 642 • **UC-MOB-2** A children's mobile device
  - 643 ○ may have multiple users
  - 644 ○ TBD
- 645 • **UC-WE-1** A wearable health tracker, such as a smart watch
  - 646 ○ stores information about a single user only
  - 647 ○ stored information may be highly sensitive, and is likely to be strictly structured (not arbitrary files)
  - 648 ○ does not have accessible I/O ports and is not user-modifiable
  - 649 ○ connects to a central service, operated by the device manufacturer, for remote data processing
  - 650 ○ connections are proxied by a trusted device, such as a mobile phone

- 651           ○ is not exposed to the internet
- 652       • **UC-ST-1** Stateless multi-user terminal
  - 653           ○ effectively a keyboard, mouse, and display connected to remote server
  - 654           ○ multiple users, one user at a time
  - 655           ○ no local data or session storage
  - 656           ○ connects to trusted local network protected by firewall
  - 657           ○ potentially available to public
  - 658           ○ professional administration
- 659       • **UC-PC-1** A personal computer in a fixed and generally safe location
  - 660           ○ hardware, software and operating system may be configured and modified by the end-user
  - 661           ○ the user may not be either highly skilled or an authorized representative of the manufacturer
  - 662           ○ foreseeably connects to the internet and to low-trust local networks, but is not reachable from the
  - 663           open internet
  - 664           ○ stores personal information and arbitrary files
- 665       • **UC-PC-2** An enterprise workstation in a fixed and generally safe location
  - 666           ○ installed in an access-controlled workspace
  - 667           ○ serviced by trained professionals who may modify both software and hardware
  - 668           ○ connected to the internet with external mitigations, such as enterprise-grade firewalls
  - 669           ○ connects to trusted local networks
  - 670           ○ hardware likely contains tamper-evident indicators and secure elements for cryptographic storage
  - 671           ○ used for web browsing
  - 672           ○ stores business data, personal information and arbitrary files
- 673       • **UC-LA-1** A personal laptop
  - 674           ○ hardware, software and operating system may be configured and modified by the end-user
  - 675           ○ device is a foreseeable target of theft and tampering by untrusted 3rd parties
  - 676           ○ stores personal information and arbitrary files
  - 677           ○ unrestricted connection to the internet
  - 678           ○ is frequently connected to untrusted networks
  - 679           ○ hardware likely contains tamper-evident indicators and secure elements for cryptographic storage
- 680       • **UC-LA-2** Enterprise laptop
  - 681           ○ hardware, software and operating system may be configured and modified by the end-user
  - 682           ○ serviced by trained professionals who may modify both software and hardware
  - 683           ○ device is a foreseeable target of theft and tampering by untrusted 3rd parties
  - 684           ○ stores business data, personal information and arbitrary files
  - 685           ○ unrestricted connection to the internet

- 686           ○ is frequently connected to untrusted networks
- 687           ○ hardware likely contains tamper-evident indicators and secure elements for cryptographic storage
- 688       • **UC-PS-1** Personal server
  - 689           ○ one or a small number of trusted users
  - 690           ○ installed in a fixed location at home or in a cohosting facility
  - 691           ○ connected to the internet with a firewall
  - 692           ○ connects to trusted local network
  - 693           ○ limited access permitted from the internet for specific services
  - 694           ○ semi-professional semi-automated management by one or a few people
  - 695           ○ always stationary, access to hardware interfaces unlikely
- 696       • **UC-SE-1** An enterprise server in a datacenter with no user accounts
  - 697           ○ installed in a monitored and secured facility
  - 698           ○ serviced by trained professionals who may modify both software and hardware
  - 699           ○ connected to the internet with external mitigations, such as enterprise-grade firewalls
  - 700           ○ connects to trusted local networks
  - 701           ○ hardware likely contains tamper-evident indicators and secure elements for cryptographic storage
- 702       • **UC-SE-2** An enterprise server in a datacenter with only trusted user accounts
  - 703           ○ Same as UC-SE-2 but with trusted users
- 704       • **UC-SE-3** An enterprise server in a datacenter hosting many untrusted user accounts
  - 705           ○ Same as UC-SE-2 but with untrusted users
- 706       • **UC-IF-1** Internet infrastructure on private network
- 707       • **UC-IF-2** Internet infrastructure on filtered network
- 708       • **UC-IF-3** Internet infrastructure on open internet
- 709       • **UC-FI-1** Firewall for personal network
- 710       • **UC-FI-2** Firewall for enterprise network
- 711   TBD:
  - 712       • More embedded use cases
  - 713       • BMCs
  - 714       • Network interfaces
  - 715       • Graphics cards
  - 716       • Real time applications
  - 717       • Other use cases for special purpose operating systems



## 4.5 Risk factors

### 4.5.1 List of risk factors

For each operating system placed on the market, the manufacturer shall develop a threat model and risk profile based on the foreseeable use of the operating system. The risk profile is derived from the foreseeable use of the product. The following risk factors shall be taken into account when developing the risk profile.

Note: “account” refers to a user in the operating systems sense: a unique system identity associated with certain authorization and permissions. “User” refers to an entity that uses the device for some purpose. Users may have many accounts and accounts may have many users.

#### 4.5.1.1 Number of Users

**[RF-NUSR]:** Manufacturers of operating systems which are intended to store personal data, including user login data, shall account for the risk to such data in the risk calculation and ensure that appropriate protections are available. System-level users (such as root) do not count towards this risk.

- NUSR-0: the operating system is designed not to allow end-users to authenticate
- NUSR-1: the operating system is designed to only allow one end-user to authenticate; to switch users, the user must factory reset the device **FIXME** is this correct?
- NUSR-2: the operating system is designed to allow for more than one end-user account

#### 4.5.1.2 User Concurrency

**[RF-CUSR]:** Manufacturers of operating systems which are intended to support end-user accounts, either concurrently or sequentially, shall account for the increased risk to per-user data from other users and ensure that appropriate protections are available. System-level users (such as root) count towards this if they are configurable or accessible by end-users.

- CUSR-0: the operating system is designed not to allow end-users to authenticate
- CUSR-1: the operating system is designed to only allow one end-user to authenticate concurrently; to switch users, the authenticated user must logout.
- CUSR-2: the operating system is designed to allow for more than one end-user account, and end-user accounts may be simultaneously active on the device.

#### 4.5.1.3 Data Storage

**[RF-DATA]:** Manufacturers of operating systems may implement measures to prevent the on-device storage of user data, and shall document this and implement appropriate steps to ensure that no user data is stored on the device. Manufacturers may also enable the storage of specific types of data or generally of any user-specified data, and shall document the measures available for the protection of such data.

- DATA-0: the operating system is effectively unable to store per-user data in its foreseeable use
- DATA-1: the operating system is designed only to store limited data types
- DATA-2: the operating system is designed to store arbitrary data

#### 4.5.1.4 Collection or sharing of sensitive personal data

**[RF-SENS]:** Manufacturers of operating systems whose common use case allows collection or sharing of sensitive personal data may implement measures to prevent or limit the collection or sharing of sensitive personal data, and shall document this and implement appropriate steps to ensure that sensitive personal data is not collected or shared. Manufacturers may also enable the collection or sharing of sensitive personal data, and shall document the measures available for the protection of such data.

- 758 • SENS-0: the operating system is effectively unable to collect sensitive personal data
- 759 • SENS-1: the operating system is designed to limit collection of sensitive personal data
- 760 • SENS-2: the operating system is designed to collect sensitive personal data
- 761 • SENS-3: the operating system is collects sensitive personal data by default

#### 762 4.5.1.5 Physical Access by Threat Actors to the Device

763 **[RF-PHYS]:** Manufacturers of operating systems may implement protective measures, such as preventing peripheral  
 764 device driver loading or relying on hardware capabilities such as tamper-evident mechanisms, to mitigate physical  
 765 access based threats to the device.

- 766 • PHYS-0: only used in environments with authorized users
- 767 • PHYS-1: may be incidentally exposed to untrusted users
- 768 • PHYS-2: used primarily by untrusted users, e.g. the general public

#### 769 4.5.1.6 Probability of Loss of the Device

770 **[RF-LOSS]:** likelihood of loss or theft should be accounted for in the risk calculation, particularly for devices that store  
 771 sensitive personal data.

- 772 • LOSS-0: foreseeable use of the operating system is limited to stationary devices or devices with other loss-  
 773 prevention mechanisms
- 774 • LOSS-1: foreseeable use of the operating system is in a device with only incidental loss likelihood
- 775 • LOSS-2: foreseeable use of the operating system is in a device with moderate loss likelihood
- 776 • LOSS-3: foreseeable use of the operating system is in a device with a high loss likelihood, such as devices  
 777 which are common targets of theft such as mobile phones

#### 778 4.5.1.7 Hardware Modifiability by End Users

779 **[RF-HWMD]:** Manufacturers of operating systems shall account for foreseeable risks from hardware modifications  
 780 within the intended use of the product.

- 781 • HWMD-0: foreseeable use of the operating system is limited to devices with hardware that is not modifiable  
 782 by end-users
- 783 • HWMD-1: foreseeable use of the operating system includes hardware modifications by skilled or trusted users,  
 784 such as corporate IT support staff
- 785 • HWMD-2: foreseeable use of the operating system includes hardware modification by unskilled users, such as  
 786 in a personal computer

#### 787 4.5.1.8 Software Modifiability by End Users

788 **[RF-SWMD]:** Manufacturers of operating systems which are designed to allow end-users to install or substantially  
 789 modify the software shall account for the risks from arbitrary software execution.

- 790 • SWMD-0: foreseeable use lacks any reasonable means for end-users to install or modify the software
- 791 • SWMD-1: foreseeable use only allows the installation of trusted and verified software
- 792 • SWMD-2: foreseeable use allows for the installation of arbitrary software or for substantial modification of  
 793 pre-installed software
- 794 • SWMD-3: foreseeable use actively encourages and facilitates the installation of arbitrary software

#### 4.5.1.9 Untrusted Peripheral Devices

**[RF-DVCS]:** Manufacturers of operating systems which are intended for devices that support attached peripheral devices, such as those utilizing USB or PCI connections, shall account for the risk posed by untrusted or compromised peripheral devices and implement appropriate safeguards.

- DVCS-0: foreseeable use has no accessible peripheral ports
- DVCS-1: foreseeable use includes only trusted and safe peripheral devices
- DVCS-2: foreseeable use allows for arbitrary peripheral device attachment

#### 4.5.1.10 Access To The Internet

**[RF-TNET]:** Manufacturers of operating systems designed to provide end-users with access to the internet shall implement appropriate safeguards based on the nature of internet access and foreseeable use of the operating system.

- TNET-0: foreseeable use has no mechanism to reasonably connect to the internet
- TNET-1: foreseeable use allows internet access for only highly restricted functions, such as retrieving security updates
- TNET-2: foreseeable use allows for arbitrary access to the internet, such as by browsing the web

#### 4.5.1.11 Accessed From Untrusted Networks Including The Internet

**[RF-FNET]:** Manufacturers of operating systems designed to be connected to directly from the internet, rather than placed behind NAT or a firewall, shall implement appropriate safeguards to mitigate risks.

- FNET-0: foreseeable use is limited to trusted and private networks
- FNET-1: foreseeable use includes untrusted local networks but not the open internet
- FNET-2: foreseeable use includes being connected directly to the open internet
- FNET-3: foreseeable use includes being a firewall connected directly to the open internet

#### 4.5.1.12 Configurability

**[RF-CONF]:** Manufacturers of operating systems which are intended to be configurable by end users shall provide secure-by-default configurations and document all available configuration options. Such documentation shall detail any effects on safety and security that such configuration changes may cause.

- CONF-0: foreseeable use of the operating system prevents or is incapable of storing configuration changes.
- CONF-1: foreseeable use allows operating system configuration changes only by skilled or trusted users, such as corporate IT support staff.
- CONF-2: foreseeable use of the operating system includes configuration changes by end-users.

### 4.5.2 Mapping of Use Cases to Risk Factors

**NOTE:** The “TOTAL” field informs the Risk Tolerance assignments table in Section 6.3

| Risk Factor | NUS R | CUS R | DAT A | SEN S | PHY S | LOS S | HW MD | SW MD | DVC S | TNE T | FNE T | CON F | TOTAL |
|-------------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|
| Use Case    | —     | —     | —     | —     | —     | —     | —     | —     | —     | —     | —     | —     | —     |

| <b>Risk Factor</b> | <b>NUS R</b> | <b>CUS R</b> | <b>DAT A</b> | <b>SEN S</b> | <b>PHY S</b> | <b>LOS S</b> | <b>HW MD</b> | <b>SW MD</b> | <b>DVC S</b> | <b>TNE T</b> | <b>FNE T</b> | <b>CON F</b> | <b>TOTAL</b> |
|--------------------|--------------|--------------|--------------|--------------|--------------|--------------|--------------|--------------|--------------|--------------|--------------|--------------|--------------|
| <b>UC-LR</b>       | 0            | 0            | 0            | 0            | 0            | 0            | 0            | 0            | 0            | 0            | 0            | 0            | 0            |
| <b>UC-IoT-1</b>    | 0            | 0            | 0            | 0            | 1            | 0            | 0            | 0            | 0            | 0            | 0            | 0            | 1            |
| <b>UC-IoT-2</b>    | 0            | 0            | 1            | 0            | 1            | 0            | 0            | 0            | 0            | 1            | 0            | 1            | 4            |
| <b>UC-IoT-3</b>    | 0            | 0            | 1            | 0            | 1            | 0            | 1            | 0            | 0            | 1            | 0            | 1            | 5            |
| <b>UC-OT-1</b>     | 0            | 0            | 1            | 0            | 1            | 0            | 0            | 0            | 0            | 2            | 2            | 2            | 8            |
| <b>UC-OT-2</b>     | 0            | 0            | 0            | 0            | 2            | 0            | 0            | 0            | 0            | 1            | 1            | 1            | 6            |
| <b>UC-MOB-1</b>    | 1            | 1            | 2            | 3            | 1            | 3            | 0            | 3            | 2            | 2            | 2            | 2            | 22           |
| <b>UC-MOB-2</b>    |              |              |              |              |              |              |              |              |              |              |              |              | –            |
| <b>UC-WE-1</b>     | 1            | 1            | 1            | 2            | 1            | 2            | 0            | 0            | 0            | 1            | 1            | 0            | 10           |
| <b>UC-ST-1</b>     |              |              |              |              |              |              |              |              |              |              |              |              | –            |
| <b>UC-PC-1</b>     | 1            | 2            | 2            | 1            | 0            | 0            | 2            | 2            | 1            | 2            | 1            | 2            | 15           |
| <b>UC-PC-2</b>     | 1            | 2            | 2            | 1            | 0            | 0            | 2            | 2            | 1            | 2            | 1            | 1            | 14           |
| <b>UC-LA-1</b>     | 1            | 2            | 2            | 1            | 1            | 1            | 1            | 2            | 2            | 2            | 2            | 2            | 19           |
| <b>UC-LA-2</b>     | 1            | 2            | 2            | 1            | 1            | 1            | 1            | 2            | 2            | 2            | 2            | 1            | 18           |
| <b>UC-SE-1</b>     | 0            | 0            | 2            | 0            | 0            | 0            | 1            | 2            | 1            | 1            | 1            | 0            | 9            |
| <b>UC-SE-2</b>     | 1            | 1            | 2            | 0            | 0            | 0            | 1            | 2            | 1            | 1            | 1            | 0            | 11           |
| <b>UC-SE-3</b>     | 2            | 2            | 2            | 0            | 0            | 0            | 1            | 2            | 1            | 1            | 1            | 0            | 13           |
| <b>UC-IF-1</b>     | 0            | 0            | 1            | 0            | 0            | 0            | 1            | 0            | 0            | 1            | 0            | 2            | 5            |

| Risk Factor | NUS R | CUS R | DAT A | SEN S | PHY S | LOS S | HW MD | SW MD | DVC S | TNE T | FNE T | CON F | TOTAL |
|-------------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|
| UC-IF-2     | 0     | 0     | 1     | 0     | 0     | 0     | 1     | 0     | 0     | 2     | 1     | 1     | 5     |
| UC-IF-3     | 0     | 0     | 1     | 0     | 0     | 0     | 1     | 0     | 0     | 3     | 2     | 1     | 8     |
| UC-FI-1     | 0     | 0     | 1     | 0     | 0     | 0     | 1     | 0     | 0     | 3     | 1     | 2     | 8     |
| UC-FI-2     | 0     | 0     | 1     | 0     | 0     | 0     | 1     | 0     | 0     | 3     | 1     | 1     | 7     |

## Discussion

Potential additional risk factors:

- Professional or amateur administration
- Is audit/logging being watched?
- Web browsing or not
- Sensitivity of data collected or transferred
- Sensitivity of functions
- Running on bare metal vs. hypervisor
- Many devices have multiple OS's for elements

Phone should be significantly riskier than a personal laptop. The phone goes everywhere, is always on, always connected, filled with sensors, super loaded with personally identifiable data, practically begs you to install with data stealing apps.

Separate question for the application delivery mechanism: 1. App is not preinstalled, but by default gets installed during initial configuration by the user if the user always picks the preselected option -> IMHO part of the device, forcing installation later should not be an allowed trick to make the scope smaller. 2. Third party app is installed through the official app store/repository, but vetted less (or not at all) by the OS vendor. Do we want to require a vetting level indicator if the same source has multiple tiers of vetting? 3. Third party app is installed through the official app store, but does not use that app store for updates, instead preferring its own update delivery mechanism. Is that something we should warn against? 4. App installation requires the user to agree to certain privileges/permissions for the app. If the app later on wants more/other permissions, are those granted implicitly (motivation: user has already installed the app, keep it working) or is explicit consent by the user necessary? 5. If the OS changes the way how app permissions are handled (bluetooth access suddenly needs location permission), should the OS guess the intent of the user or should the user be re-asked all the permission questions?

Aeva: Carl-Daniel's comment could also apply to enterprise computers (laptops, desktops, servers) – most also contain a second OS for remote management.

## 4.6 Risk Tolerance

**NOTE:** Tolerance is inversely proportional to the product of (potential harm) x (likelihood) of an exploited risk.

- [RT-C] / [RT-1]: The product is suitable for use in highly sensitive or critical environments.
- [RT-L] / [RT-2]: The product is suitable for use in environments with low risk tolerances.
- [RT-M] / [RT-3]: The product is suitable for use in environments with medium risk tolerances. Some security tradeoffs may be made to improve usability and potential harms from unmitigated risk are widely acceptable.

- 857 • **[RT-H] / [RT-4]:** The product is suitable for use in environments with high risk tolerances. Potential harms
- 858 from unmitigated risks are low or negligible, and users are unlikely to reasonably expect security updates
- 859 within the product's foreseeable use.

## 860 4.7 Essential functions

861 An operating system may provide, depending on the hardware available and its configuration:

- 862 • Resource allocation
  - 863 ○ Memory management
  - 864 ○ Scheduling
  - 865 ○ Storage quotas
  - 866 ○ Other resource usage limits
- 867 • Isolation
  - 868 ○ Memory protection
  - 869 ○ Storage protection
  - 870 ○ Other permissions
- 871 • Abstract I/O
  - 872 ○ Network stack
  - 873 ○ File systems
  - 874 ○ Video
  - 875 ○ Sound
  - 876 ○ Input devices (mouse, keyboard)
- 877 • Hardware communication
  - 878 ○ Device drivers
- 879 • Power management
- 880 • Hardware management
- 881 • Configuration
  - 882 ○ Software to run
  - 883 ○ Hardware configuration
  - 884 ○ I/O configuration (network, etc.)
- 885 • Initialization
  - 886 ○ Initialize hardware
  - 887 ○ Start software services
- 888 • Authentication
- 889 • Authorization
- 890 • Software management

- 891           ○ Security updates
- 892           ○ Software upgrade
- 893           ○ Software installation
- 894           ○ Software verification
- 895           ○ Firmware upgrades
- 896           ○ Load kernel modules

- 897       • Logging
- 898       • Monitoring/notifications

899                 FIXME Put this in a diagram with dependencies and interface/attack surface?

## 900   4.8 Operational Environment

901   The technical requirements of the present document apply under the environmental profile for operation of the  
 902   equipment, which shall be in accordance with its intended use. The equipment shall comply with all the technical  
 903   requirements of the present document at all times when operating within the boundary limits of the operational  
 904   environmental profile defined by its intended use.

905   The manufacturer shall document and communicate the expected environmental profile for the product to the consumer.

## 906   4.9 Users

- 907       • General public
- 908       • Children
- 909       • Assistants to primary user
- 910       • IT professionals
- 911       • Systems integrators
- 912       • Software developers

## 913   4.10 Distribution of security functions

### 914   4.10.1 General

915   For each security requirement, a product may:

- 916       1. Provide all necessary security functions itself
- 917       2. Require security functions be provided by some other part of its context
- 918       3. Provide security functions for the use of other components

919   For example, most individual hardware components do not have a built-in method of securely updating any firmware in  
 920   the product. Usually this requires a full-featured system running an operating system which can check for firmware  
 921   updates, download and verify them, and carry out the process of updating the firmware.

## 922 4.10.2 Security functions provided outside the product

923 The operating system relies on correctly functioning hardware to implement its functions. It relies on security functions  
 924 and configuration provided by the environment, hardware, boot manager, and any virtualization prior to the beginning  
 925 of its execution. Such security functions may include:

- 926 • Memory protection
- 927 • Secure or measured boot
- 928 • Confidential data transmission
- 929 • Encryption of data at rest
- 930 • Secure updates
- 931 • Access control

## 932 4.10.3 Security functions provided to other components

933 The operating system often provides many security functions to other components of the system, including:

- 934 • Secure by default configuration
- 935 • Secure updates
- 936 • Authentication and access control mechanisms
- 937 • Confidentiality protection
- 938 • Integrity protection for data and configuration
- 939 • Data minimization
- 940 • Availability protection
- 941 • Minimize impact on other devices or services
- 942 • Limit attack surface
- 943 • Exploit mitigation by limiting incident impact
- 944 • Logging and monitoring mechanisms
- 945 • Secure deletion and data transfer



## 5 Requirements specifications

### 5.1 Notes on the structure of requirements

The most important quality of a technical requirement is that it should ideally be objectively testable on an instance of the product and the documentation that is required to be produced and saved by the manufacturer (and provided to the MSA on request).

The alternative option is “check-box” requirements, which only require that the vendor document that they did a thing (“Did you have every commit code-reviewed by a second person? [x] Yes [ ] No”).

We should prefer testable requirement to check-box requirements, but when a requirement isn’t testable, we can provide a decision tree where the vendor follows specific instructions to document why they have to use a check-box requirement (something that is documentation-only).

The goal is that when the MSA does a “sweep” or otherwise decides to verify a product’s conformance with the CRA, it has enough information that it can do its own independent testing without unnecessary barriers that could be solved by vendor documentation (e.g., does not have to reverse-engineer how to attach a serial console and read logs).

How exactly this will be done is yet to be determined, but here is our proposal:

- The vendor’s documentation must include information about each test it ran, including:
  - any physical equipment other than the product’s normal operating environment
  - any testing software they used, including versions
  - documentation for any testing software or hardware used
  - the parameters or arguments they used for the software or hardware
  - any setup information for the test (load this module, flip this switch, run this script, etc.)
- The standard can include requirements for the tools used in the test itself (features or sensitivity or maybe even source code available?)
- Any tests should demonstrate both the failure and success version of the test to rule out false positives or negatives

Mitigations are how a technical requirement can be satisfied. Mitigations must be tailored to the use case and take into account the user’s sophistication and the operational environment.

### 5.2 Technical security requirements specifications

#### 5.2.1 General

This section is a list of technical requirements necessary to satisfy the CRA essential requirements. Each technical requirement can be satisfied by one or more potential mitigations. Each mitigation may or may not be appropriate for an individual use case. The following section will define which mitigations will be required, depending on a risk factor, the overall risk tolerance, and/or a use case in the following section.

Each mitigation is described with the following fields:

- Mitigation: brief description of the mitigation
- Test: how to test that the mitigation is implemented
- Result: what output
- Output: the warning or error message produced by the checker

- 983 • False negative/positive prevention: if necessary, a way to prove that the test distinguishes between conformant
- 984 and non-conformant products
- 985 • Requirements: features of the product as placed on the market necessary to run the test
- 986 • Documentation: what data the manufacturer must save for provision to the MSA

## 987 5.2.X TR-MISO: Memory isolation

### 988 5.2.X.1 Threat description

989 Threat: attacker tries to access memory that belongs to another user or the kernel in an unauthorized manner.

### 990 5.2.X.x MI-SSCA: Static source code analysis for memory protection

991 Use case: operating systems where all executables share a single address space, memory protection settings, and  
 992 processor privilege level (e.g. embedded, low power, special purpose, unikernel)

- 993 • Mitigation: statically check source code for out-of-bounds memory access
- 994 • Test: source code that accesses memory out-of-bounds in a variety of defined ways (TBD)
- 995 • Result: warning or error
- 996 • Output: the warning or error message produced by the checker
- 997 • False positive test: source code that does not access memory out of bounds does not produce the warning or  
 998 error
- 999 • Requirements: board support package
- 1000 • Documentation: source code and output of the tests, source code of operating system, checker information

### 1001 5.2.X.x MI-MMUP: Memory protection using MMU

1002 Use case: Any operating system that requires process isolation (anything with multiple users, potentially untrusted  
 1003 users, untrusted userspace executables, etc.)

- 1004 • Mitigation: Use MMU to mark memory regions as inaccessible to an executable before scheduling it
- 1005 • Test: Attempt to read, write, or execute memory in a different memory isolation domain
- 1006 • Result: error, trap, signal, or kill thread
- 1007 • Output: executes error handling code or thread is killed
- 1008 • Requirements: ability to compile and execute code
- 1009 • Documentation: test source code, instructions to compile, output of error handling or log message for thread  
 1010 kill

## 1011 5.2.X TR-OOBM: Out-of-bounds memory access prevention or mitigation

1012 FIXME: should all of this be required for executables running with elevated privileges?

### 1013 5.2.X.1 Threat description

1014 Threat: attacker uses an operating systems vulnerability to access memory in an unauthorized manner while possessing  
 1015 elevated memory access privileges.

## 1016 5.2.X.x **MI-KSED**: Kernel stack exhaustion detection

1017 Use case: phone, general purpose, desktop, server, router, firewall

- 1018 • Sub-threat: kernel stack exhaustion causes thread to write beyond end of stack
- 1019 • Mitigation: kernel validates the limits of the kernel stack
- 1020 • Test: perform unbounded recursive kernel call to use all stack memory
- 1021 • Result: thread is killed
- 1022 • Output: action logged as an event or the OS reboots
- 1023 • Requirements: way to read log output on product as shipped, ability to build and run new kernel code
- 1024 • Documentation: source code of test, log output during test

## 1025 5.2.X.x **MI-KSBO**: Kernel stack linear buffer overflow detection

- 1026 • Sub-threat: unbounded kernel stack buffer write goes beyond stack frame
- 1027 • Mitigation: kernel stack frame limits validated
- 1028 • Test: write beyond the end of a stack buffer
- 1029 • Result: thread is killed
- 1030 • Output: action logged as an event or the OS reboots
- 1031 • Requirements: way to read log output on product as shipped
- 1032 • Documentation:

## 1033 5.2.X.x **MI-KABC**: Kernel array bounds checking

- 1034 • Sub-threat: unbounded kernel array access
- 1035 • Mitigation: array bounds validated
- 1036 • Test: declare an array of fixed size and write beyond the max index
- 1037 • Result: thread is killed
- 1038 • Output: action logged as an event or the OS reboots
- 1039 • Requirements: way to read log output on product as shipped
- 1040 • Documentation:

## 1041 5.2.X. **MI-KHLO**: Kernel heap linear overflow detection

- 1042 • Sub-threat: kernel heap memory overflow
- 1043 • Mitigation: check heap memory allocation bounds
- 1044 • Test: in separate threads, allocate a fixed size from each class of kernel heap memory, write beyond it
- 1045 • Result: each thread killed
- 1046 • Output: action logged as an event or the OS reboots
- 1047 • Requirements: way to read log output on product as shipped

- 1048 • Documentation:

#### 1049 5.2.X. **MI-KUFW**: Kernel heap user-after-free write prevention

- 1050 • Sub-threat: kernel heap use-after-free write
- 1051 • Mitigation: memory tagging prevents use of un/re-allocated memory
- 1052 • Test: allocate kernel heap memory, free it, write to the allocation
- 1053 • Result: thread killed
- 1054 • Output: action logged as an event or the OS reboots
- 1055 • Requirements: way to read log output on product as shipped
- 1056 • Documentation:

#### 1057 5.2.X. **MI-KUFR**: Kernel heap user-after-free read prevention

- 1058 • Sub-threat: kernel heap use-after-free read
- 1059 • Mitigation: memory tagging prevents use of un/re-allocated memory
- 1060 • Test: allocate kernel heap memory, free it, read from the allocation
- 1061 • Result: thread killed
- 1062 • Output: action logged as an event or the OS reboots
- 1063 • Requirements: way to read log output on product as shipped
- 1064 • Documentation:

#### 1065 5.2.X. **MI-KHFC**: Kernel heap free checking

- 1066 • Sub-threat: kernel heap free corruption
- 1067 • Mitigation: validate heap origin on free
- 1068 • Test: allocate kernel heap, free it twice
- 1069 • Result: second free is rejected
- 1070 • Output: action logged as an event or the OS reboots
- 1071 • Requirements: way to read log output on product as shipped
- 1072 • Documentation:

#### 1073 5.2.X. **MI-KSMZ**: Kernel stack memory zeroing

- 1074 • Sub-threat: uninitialized kernel stack memory controlled by attacker
- 1075 • Mitigation: zero-initialize all kernel stack memory before use
- 1076 • Test: sequentially call 2 functions that allocate the same amount of memory, fill the first with known values and return, and during second function call, read the stack contents back
- 1077
- 1078 • Result: stack contents are clear on second call
- 1079 • Output: action logged as an event
- 1080 • Requirements: way to read log output on product as shipped

- Documentation:

#### 5.2.X. **MI-KHMO**: Kernel heap memory zeroing

- Sub-threat: uninitialized kernel heap memory controlled by attacker
- Mitigation: zero-initialize all kernel heap memory before use
- Test: allocate heap memory, fill with a known value, free it, allocate it again in a deterministic way to get the same heap region, and read back the contents
- Result: heap contents are clear on second allocation
- Output: action logged as an event
- Requirements: way to read log output on product as shipped
- Documentation:

#### 5.2.X. **MI-KLLP**: Kernel linked list protection

- Sub-threat: kernel doubly linked list corruption
- Mitigation: linked list implementation checks prev/next pointers on add/del
- Test: add or delete an item to an uninitialized list
- Result: thread is killed
- Output: action logged as an event or the OS reboots
- Requirements: way to read log output on product as shipped
- Documentation:

#### 5.2.X. **MI-KPXM**: Prevent execution of non-kernel code memory

- Sub-threat: Non-code executable kernel memory
- Mitigation: Only kernel code memory regions are executable
- Test: copy a trivial return-only function into every class of non-code memory in the kernel (e.g. stack, heap, read-only data), one to a thread, and attempt to execute each one
- Result: each thread is killed
- Output: action logged as an event or the OS reboots
- Requirements: way to read log output on product as shipped
- Documentation:

#### 5.2.X. **MI-KPWM**: Prevent writes to kernel code and read-only data memory

- Sub-threat: Writable kernel code or read-only memory
- Mitigation: All kernel code memory and non-writable data is read-only
- Test: from separate threads, write to each portion of kernel code and non-writable data region
- Result: each thread killed
- Output: action logged as an event or the OS reboots

- 1114 • Requirements: way to read log output on product as shipped
- 1115 • Documentation:

#### 1116 5.2.X. **MI-KPUM**: Prevent unintentional kernel access to unprivileged memory

- 1117 • Sub-threat: Unexpected access to userspace memory from OS kernel
- 1118 • Mitigation: block cross-privilege level memory read/write/execute
- 1119 • Test: in separate kernel threads, read, write, and execute memory regions that are mapped to userspace without
- 1120 going through dedicated userspace memory access routines
- 1121 • Result: each thread killed
- 1122 • Output: action logged as an event or the OS reboots
- 1123 • Requirements: way to read log output on product as shipped
- 1124 • Documentation:

#### 1125 5.2.X. **MI-KRCP**: Kernel reference counter protection

- 1126 • Sub-threat: Kernel reference counter overflow
- 1127 • Mitigation: bounds check reference counters
- 1128 • Test: set resource reference counter to 1 less than maximum representable value, increment it twice
- 1129 • Result: reference counter does not overflow but resource is pinned
- 1130 • Output: action logged as an event or the OS reboots
- 1131 • Requirements: way to read log output on product as shipped
- 1132 • Documentation:

#### 1133 5.2.X.x **MI-KFCI**: Kernel forward control flow integrity

- 1134 • Sub-threat: Kernel function pointer overwrite
- 1135 • Mitigation: Protect saved function pointers from overwrite
- 1136 • Test: Save a kernel function pointer to heap, overwrite it with a different function, make indirect call to the
- 1137 saved function pointer
- 1138 • Result: thread is killed
- 1139 • Output: action logged as an event or the OS reboots
- 1140 • Requirements: way to read log output on product as shipped
- 1141 • Documentation:

#### 1142 5.2.X.x **MI-XXXX**: Memory protection using Pointer Authentication Codes

- 1143 Use case: phone, other devices at higher risk of malicious code execution
- 1144 • Mitigation:
- 1145 • Test:
- 1146 • Result:

- 1147       • Output:
- 1148       • False positive test:
- 1149       • Requirements:
- 1150       • Documentation:

#### 1151   5.2.X.x **MI-XXXX**: Memory protection using hardware memory tagging

1152   Use case: phone, other devices at higher risk of malicious code execution

- 1153       • Mitigation: Use hardware memory tagging feature for kernel memory allocations
- 1154       • Test: Allocate memory with a tag, attempt to access the memory without the tag
- 1155       • Result: segmentation fault, error handling code executed or thread killed
- 1156       • Output: error message or log message for killed thread
- 1157       • Requirements: way to read output on product as shipped
- 1158       • Documentation: source code of tests, output of error message or thread kill

#### 1159   5.2.X.x **MI-XXXX**: Memory protection using enhanced hardware memory tagging

1160   Use case: phone, other devices at higher risk of malicious code execution

- 1161       • Mitigation: Use enhanced hardware memory tagging feature for kernel memory allocations
- 1162       • Test: Allocate memory with a tag, attempt to access the memory without the tag
- 1163       • Result: segmentation fault, error handling code executed or thread killed
- 1164       • Output: error message or log message for killed thread
- 1165       • Requirements: way to read output on product as shipped
- 1166       • Documentation: source code of tests, output of error message or thread kill

### 1167   5.2.X **TR-LSRE**: Logging of security-relevant events

#### 1168   5.2.X.1 Threat description

1169   Threat: attacker's security-relevant changes to systems can't be tracked or audited

#### 1170   5.2.X.x **MI-LLOG**: Local logging

1171   Use case: Everything above toy that has security-relevant configuration?

- 1172       • Mitigation: Keep local logs of important security events with timestamps, including TBD:
  - 1173           ○ list of types of events
  - 1174           ○ enough information to directly repair the change without scanning the whole system
  - 1175           ○ enough log storage ??? amount
- 1176       • Test: For each type of logged event, execute the action that should be logged
- 1177       • Result: Log output for each event
- 1178       • Output: Log output for each event

- 1179       • Requirements: way to read log output on product as shipped
- 1180       • Documentation: list of security-relevant configuration, description of tests, source code of tests, output of tests

## 1181   5.2.X.x **MI-RLOG**: Remote logging

1182   Use case: Higher risk servers, workstations, laptops, anything that can't write logs locally?

- 1183       • Mitigation: same as MI-LLOG but with ability to send logs via a verifiable channel to an authorized log server,  
1184       as long as the connection to the server is available
- 1185       • Test: For each type of logged event that would result in the logging server becoming unavailable, execute the  
1186       action that would result in that log event
- 1187       • Result: Log output for each event is sent to log server
- 1188       • Output: Log output for each event as sent to log server
- 1189       • Requirements: way to setup remote log server for product as shipped
- 1190       • Documentation: description of tests, source code of tests, output of tests, instructions for setting up log server

## 1191   5.2.X **TR-LLTP**: Local log tamper prevention

### 1192   5.2.X.1 Threat description

1193   Threat: attacker tampers with log messages

## 1194   5.2.X.x **MI-LLGA**: Local log file only editable by privileged users

1195   Use case: Any product with multiple users?

- 1196       • Mitigation: log file has permissions allowing editing only by users with appropriate privileges
- 1197       • Test: attempt to write to, delete, and move each log file by an unauthorized user
- 1198       • Result: access is denied, log is not changed
- 1199       • Output: error messages, comparison of log status shows no changes
- 1200       • Requirements: way to attempt to tamper with logs on product as shipped, way to read log output
- 1201       • Documentation: how to get access to the device to attempt log tampering, source code of tests, documentation  
1202       to run tests, output of tests

1203   FIXME: what about append-only?

1204   Note: all security-relevant configuration handled by a different requirement

## 1205   5.2.X **TR-RLTP**: Remote log tamper prevention

### 1206   5.2.X.1 Threat description

1207   Threat: Attacker intercepts, alters, or replaces log message stream to remote log server

## 1208   5.2.X.x **MI-RLSA**: Remote log server authentication

- 1209       • Mitigation: Authentication of remote log server
- 1210       • Test: Attempt to intercept initial connection to log server using identical responses as the authorized log server,  
1211       except where using only publicly available information would be different



- 1212 • Result: Failure to connect to remote log server
- 1213 • Output: Log message, error message, no logs are sent
- 1214 • Requirements: way to read local log output
- 1215 • Documentation: documentation, source, output for tests, information/software necessary to masquerade as a
- 1216 log server

#### 1217 5.2.X.x **MI-RLET**: Encrypt log message stream with tamper-evident protocol

1218 Use case: Higher risk servers, workstations, laptops?

- 1219 • Mitigation: Use tamper-resistant encryption on the log stream such as TBD LIST OR REFER
- 1220 • Test: Alter, insert, and delete log message stream using only publicly available data
- 1221 • Result: Log server rejects tampered/false log message
- 1222 • Output: Local log shows lack of confirmation of data sent or error message indicating loss/corruption of data
- 1223 • Requirements: way to read local log output
- 1224 • Documentation: documentation, source, output for tests

#### 1225 5.2.X **TR-PCFG**: Prevent unauthorized changes of security-relevant 1226 configuration

##### 1227 5.2.X.1 Threat description

1228 Threat: Unauthorized user changes security-relevant configuration

#### 1229 5.2.X.x **MI-CFGA**: Security-relevant configuration not editable by unauthorized user

1230 Use case: Every product that has multiple user privilege levels?

- 1231 • Mitigation: Security relevant configuration can only be edited by authorized user
- 1232 • Test: For each security-relevant configuration item, attempt to edit, delete, or disable
- 1233 • Result: Failure messages, configuration does not change
- 1234 • Output: Failure messages, before and after comparison of configuration shows no change
- 1235 • Requirements: way to attempt configuration changes as unauthorized user, way to read error messages, way to
- 1236 compare configuration before and after
- 1237 • Documentation: list of all security-relevant configuration items, source, description, output of tests,
- 1238 documentation on how to set up tests, read configuration

1239 Copy-n-paste mitigation format

#### 1240 5.2.X **TR-XXXX**:

##### 1241 5.2.X.1 Threat description

1242 Threat:

#### 1243 5.2.X.x **MI-XXXX**:

1244 Use case:

- 1245 • Mitigation:
- 1246 • Test:
- 1247 • Result:
- 1248 • Output:
- 1249 • False positive test:
- 1250 • Requirements:
- 1251 • Documentation:

## 1252 NOTES

1253 Could requirements be tested by checking for the configuration options? Or do we want to give some instructions to the  
 1254 manufacturer on how to tell what settings or features will satisfy the requirements?

1255 [https://kspp.github.io/Recommended\\_Settings](https://kspp.github.io/Recommended_Settings)

1256 Technical requirements notes/sources:

1257 From NIAP PP for OS:

- 1258 • Cryptographic support
  - 1259 ○ Cryptographic key generation
  - 1260 ○ Cryptographic key establishment
  - 1261 ○ Cryptographic key destruction
  - 1262 ○ Encryption/decryption
  - 1263 ○ Cryptographic hashing/signing/authentication
  - 1264 ○ Random data generation
  - 1265 ○ Secure encrypted data storage
- 1266 • User data protection
  - 1267 ○ Access controls
  - 1268 ○ VPN
- 1269 • Security management
  - 1270 ○ Management of security functions
  - 1271 ○ Minimum security functions provided by user type
- 1272 • Protection of security relevant assets (?)
  - 1273 ○ Access controls to system data/assets
  - 1274 ○ Address space layout randomization
  - 1275 ○ Limitation of Bluetooth Profile Support
  - 1276 ○ Software Restriction Policies
  - 1277 ○ Stack buffer overflow protection
  - 1278 ○ Boot integrity
  - 1279 ○ Trusted update for OS

- 1280                   ○ Trusted update for applications and other components
- 1281                   ○ Read-only executable memory
- 1282           • Audit data generation
- 1283                   ○ Logging with timestamps
- 1284           • Identification and authorization
- 1285                   ○ Prevent brute force
- 1286                   ○ Multifactor auth
- 1287                   ○ Certificate validation
- 1288                   ○ Certificate authentication
- 1289           • Trusted paths/channels
- 1290                   ○ Allows communication via secure channel (TLS etc.)
- 1291   From BSI Operating Systems Protection Profile:
- 1292           • Audit
- 1293                   ○ Audit data generation
- 1294                   ○ Audit review
- 1295                   ○ Audit review restriction
- 1296                   ○ Protected audit data storage
- 1297                   ○ Notification of possible audit data loss
- 1298                   ○ Prevention of possible audit data loss
- 1299           • Cryptographic services
- 1300                   ○ Cryptographic key generation
- 1301                   ○ Cryptographic key distribution
- 1302                   ○ Cryptographic key destruction
- 1303                   ○ Cryptographic operation
- 1304           • Data access control
- 1305                   ○ Access control of persistent data (files)
- 1306                   ○ Access control of temporary data (pipes)
- 1307                   ○ Network information flow control
- 1308                   ○ Import user data with access control
- 1309                   ○ Secure deletion
- 1310           • Authentication
- 1311                   ○ Detect and prevent brute force attacks on auth
- 1312                   ○ User attribute storage
- 1313                   ○ Secret verification
- 1314                   ○ Auth before accessing any security functions

- 1315           ○ Multifactor auth
- 1316           ○ Obscure auth feedback
- 1317           ○ Identification before access
- 1318          • Secure configuration change and data access
- 1319           ○ Something about ACLs?
- 1320           ○ Security roles
- 1321          • Reliable timestamps
- 1322          • Session locking
- 1323           ○ Automatic
- 1324           ○ User-initiated
- 1325          • Trusted channel (secure network access)
- 1326 From Ubuntu Security Features: \* Privilege restriction \* DAC / MAC \* AppArmor \* SELinux \* SMACK \* process
- 1327 privilege restrictions \* PR\_SET\_SECCOMP \* seccomp filtering \* file system capabilities \* Storage and Filesystem \*
- 1328 Full Disk Encryption \* LVM Encryption \* File Encryption \* Network and Firewalls \* No Open Ports \* SYN cookies \*
- 1329 Firewall \* Cryptography \* Password Hashing \* Cloud PRNG Seed \* Disabling Legacy TLS \* Process and memory
- 1330 protection \* Sym-/Hard-Link restrictions \* FIFO restrictions \* (process-internal) memory protection \* Stack Protector \*
- 1331 Heap Protector \* Stack ASLR \* Libs/mmap ASLR \* Exec ASLR \* brk ASLR \* vDOS ASLR \* Default compiler and
- 1332 linker flags \* Built as PIE \* Built with Fortify Source \* Built with RELRO \* Built with BIND\_NOW \* Built with -
- 1333 fstack-clash-protection \* Built with -fcf-protection \* Non-Executable Memory \* /proc/\$pid/maps protection \* ptrace
- 1334 scope \* 0-address protection \* /dev/mem protection \* Kernel protections \* Kernel Lockdown \* /dev/kmem disabled \*
- 1335 Block module loading \* Read-only data sections \* Kernel Stack protector \* Module RO/NX \* Kernel Address Display
- 1336 Restriction \* kASLR \* denylist rare protocols \* dmesg restriction \* Block kexec \* Platform protections \* UEFI Secure
- 1337 Boot \* usb-related \* usbguard \* usbauth \* bolt \* thunderbolt-tools \* TPM \* Security updates \* Livepatch \* Automatic
- 1338 security updates
- 1339 Random ideas
- 1340          • Disable debugging interfaces in many many places
- 1341          • TPM and TEE support
- 1342          • Secure boot/ crypto authenticated boot
- 1343          • Measured boot
- 1344          • Remote attestation
- 1345          • Don't require login to online account
- 1346          • Make rules about opt-in being required
- 1347          • Everything shipped/included by manufacturer is the responsibility of the manufacturer (would cut down on
- 1348 junkware)
- 1349          • Opt-in for all network functionality
- 1350          • What about commonly disabled features for minimization
- 1351 Potential additional sources of security requirements
- 1352          • [NCP Checklists](#)
- 1353          • MSCERT (?)
- 1354          • [MITRE EMB3D](#):

- 1355 • <https://trustedcomputinggroup.org/resources/>
- 1356 • [https://trustedcomputinggroup.org/wp-content/uploads/TCG-Secure-Update-of-SW-and-FW-on-Devices-](https://trustedcomputinggroup.org/wp-content/uploads/TCG-Secure-Update-of-SW-and-FW-on-Devices-v1r72_pub.pdf)
- 1357 [v1r72\\_pub.pdf](https://trustedcomputinggroup.org/wp-content/uploads/TCG-Secure-Update-of-SW-and-FW-on-Devices-v1r72_pub.pdf)
- 1358 • Read exploit reports and CVEs
- 1359 • [ETSI EN 303 645](#)
- 1360 • [CHERI BSD](#)
- 1361 • [ETSI EN 103 732](#)
- 1362 Probably the most digestible is Ubuntu: <https://documentation.ubuntu.com/security/docs/security-features/>
- 1363 they have the “qa regression test” suite, which has a bunch of security testing (search “security” in here):
- 1364 <https://git.launchpad.net/qa-regression-testing/tree/scripts>
- 1365 for example, config testing: <https://git.launchpad.net/qa-regression-testing/tree/scripts/test-kernel-security.py>
- 1366 behavioral testing: <https://git.launchpad.net/qa-regression-testing/tree/scripts/kernel-security>
- 1367 Chrome OS security principles: [https://www.chromium.org/chromium-os/developer-library/reference/security/security-](https://www.chromium.org/chromium-os/developer-library/reference/security/security-whitepaper/#principles-of-chromeos-security)
- 1368 [whitepaper/#principles-of-chromeos-security](https://www.chromium.org/chromium-os/developer-library/reference/security/security-whitepaper/#principles-of-chromeos-security)
- 1369 Much of the Chrome OS testing has been slowly getting merged into the much more complex Android stuff below...
- 1370 Android. This is weird to navigate, but start here: <https://source.android.com/docs/security/overview>
- 1371 on the left will be “Kernel security”, “App security”, “Implement security”. Linked in there is the Compatibility
- 1372 Definition Document (CDD), which is “you have to do this to say you’re an ‘Android’ device”:
- 1373 <https://source.android.com/docs/compatibility/cdd>
- 1374 The latest is 16: <https://source.android.com/docs/compatibility/16/android-16-cdd>
- 1375 the CDD has an extensive security section: [https://source.android.com/docs/compatibility/16/android-16-](https://source.android.com/docs/compatibility/16/android-16-cdd#9_security_model_compatibility)
- 1376 [cdd#9\\_security\\_model\\_compatibility](https://source.android.com/docs/compatibility/16/android-16-cdd#9_security_model_compatibility)
- 1377 including specific features: [https://source.android.com/docs/compatibility/16/android-16-cdd#97\\_security\\_features](https://source.android.com/docs/compatibility/16/android-16-cdd#97_security_features)
- 1378 The *testing* for the CDD is the Android Compatibility Test Suite (CTS):
- 1379 <https://source.android.com/docs/compatibility/cts>
- 1380 Which has kernel security tests, for example, though it is a bit minimal:
- 1381 [https://cs.android.com/android/platform/superproject/+/android-latest-](https://cs.android.com/android/platform/superproject/+/android-latest-release:cts/hostsidetests/security/src/android/security/cts/KernelConfigTest.java)
- 1382 [release:cts/hostsidetests/security/src/android/security/cts/KernelConfigTest.java](https://cs.android.com/android/platform/superproject/+/android-latest-release:cts/hostsidetests/security/src/android/security/cts/KernelConfigTest.java)
- 1383 **Hardware-Based Countermeasures**
- 1384 • Secure boot with HW Root of Trust: Ensures that only authenticated firmware is executed, anchored in
- 1385 immutable hardware
- 1386 • Hardware-backed Key Storage (e.g., TPM, Secure Enclave): Protects cryptographic keys from software-level
- 1387 attacks and unauthorized access
- 1388 • Memory Protection Units (MPU and/or MMU): Enforces access control policies at hardware level, isolating
- 1389 critical OS components
- 1390 • Hardware-enforced Execution Zones (e.g., ARM TEE): Enables secure execution environments for sensitive
- 1391 operations.
- 1392 • Bootloader Locking and Firmware/SW Anti-rollback: Prevents downgrading to vulnerable firmware/SW
- 1393 versions.
- 1394 • Hardware Watchdog Timers: Detects and recovers from system hangs or malicious loops
- 1395 • Secure Debug Interface Management: Disabling or restricting access through state-of-the-art security
- 1396 mechanisms debug access

## 1397 5.3 Risk Mitigation Sets

1398 **TODO:** Connect the technical security requirements in Section 5.2 to specific Risk  
1399 Factors, and define these as sets of Risk Mitigations that will be referenced in  
1400 section 6.

## 6 Security Profiles

### 6.1 General

Security Profiles are mapped one-to-one to each Use Case (defined in Section 4.4).

Each Security Profile connects one Use Case to its relevant Risk Factors (defined in Section 4.5) and necessary Risk Mitigations (defined in Section 5.3).

Risk Tolerances are applied to the foreseeable risks associated to each Security Profile, relative to potential severity and likelihood of an incident affecting users.

### 6.2 Details of Security Profiles

#### 6.2.1 SP-IoT-1 :: RT-HIGH

Description: A non-internet-connected device such as a bluetooth speaker

| Use Case | NUS R | CUS R | DAT A | SEN S | PHY S | LOS S | HW MD | SW MD | DVC S | TNE T | FNE T | CON F | TOTAL |
|----------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|
| UC-IoT-1 | 0     | 0     | 0     | 0     | 1     | 0     | 0     | 0     | 0     | 0     | 0     | 0     | 1     |

- Risk Factor Score: 1
- Risk Analysis
  - There is no network risk since the device lacks wireless networking capabilities.
  - There is negligible risk to user data since the device does not store or process any sensitive or personal data.
  - While untrusted users may gain physical access to the device, likelihood of tampering is lower than likelihood of theft.
  - Interception of non-network wireless signals, such as audio connections, should be considered in the threat model.
- Risk Mitigations
  - TBD - maybe none?
- Derived Risk Tolerance: HIGH (4)

#### 6.2.2 SP-IoT-2 :: RT-HIGH

Description: An internet-enabled power switch

| Use Case | NUS R | CUS R | DAT A | SEN S | PHY S | LOS S | HW MD | SW MD | DVC S | TNE T | FNE T | CON F | TOTAL |
|----------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|
| UC-IoT-2 | 0     | 0     | 1     | 0     | 1     | 0     | 0     | 0     | 0     | 1     | 0     | 1     | 4     |

- Risk Factor Score: 4
- Risk Analysis
  - Network risk is present since the device relies on wireless networking capabilities for essential functions, but mitigated because the device only connects to trusted networks.

- 1429 ○ There is low risk to user data since the device does stores personal data necessary to carry out its
- 1430 functions. However, the device does not store any sensitive personal data.
- 1431 ○ Device misconfiguration by end users may lead to insecure operation.
- 1432 • Risk Mitigations
- 1433 ○ TBD - probably some!
- 1434 ○ e.g., remote update capability, conformance to wireless security standards, secure-by-default guidance
- 1435 • Derived Risk Tolerance: HIGH (4)

### 1436 6.2.3 SP-IoT-3 :: RT-HIGH

1437 Description: An internet-connected “smart home” device, such as a thermostat, fridge, or alarm system

| Use Case | NUS R | CUS R | DAT A | SEN S | PHY S | LOS S | HW MD | SW MD | DVC S | TNE T | FNE T | CON F | TOTAL |
|----------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|
| UC-IoT-3 | 0     | 0     | 1     | 0     | 1     | 0     | 1     | 0     | 0     | 1     | 0     | 1     | 5     |

- 1438 • Risk Factor Score: 5
- 1439 • Risk Analysis
- 1440 ○ Network risk is present since the device relies on wireless networking capabilities for essential
- 1441 functions, but mitigated because the device only connects to trusted networks.
- 1442 ○ There is low risk to user data since the device does stores personal data necessary to carry out its
- 1443 functions. However, the device does not store any sensitive personal data.
- 1444 ○ Device misconfiguration by end users may lead to insecure operation.
- 1445 ○ Users are likely to physically interact with the device on a regular basis, so the device should protect
- 1446 against malicious peripherals.
- 1447 • Derived Risk Tolerance: HIGH (4)

### 1448 6.2.4 SP-OT-1 :: RT-????

1449 Description: A consumer-grade home wireless router |UC-OT-1| 0|0|1|0|1|0|0|0|0|2|2|2|8|

### 1450 6.2.5 SP-OT-2 :: RT-????

1451 Description: A business-grade remote door locking system |UC-OT-2| 0|0|0|0|2|0|0|0|0|1|1|1|6|

### 1452 6.2.6 SP-MOB-1 :: RT-????

1453 Description: A personal smart phone |UC-MOB-1| 1|1|2|3|1|3|0|3|2|2|2|2|22|

### 1454 6.2.7 SP-WE-1 :: RT-????

1455 Description: A wearable health tracker, such as a smart watch |UC-WE-1| 1|1|1|2|1|2|0|0|0|1|1|0|10|

### 1456 6.2.8 SP-ST-1 :: RT-????

1457 Description: Stateless multi-user terminal



## 6.2.9 SP-PC-1 :: RT-LOW

Description: A personal computer in a fixed and generally safe location

| Use Case | NUS R | CUS R | DAT A | SEN S | PHY S | LOS S | HW MD | SW MD | DVC S | TNE T | FNE T | CON F | TOTAL |
|----------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|
| UC-PC-1  | 1     | 2     | 2     | 1     | 0     | 0     | 2     | 2     | 1     | 2     | 1     | 2     | 15    |

- Risk Factor Score: 15
- Risk Analysis
  - Network risk is high since the device connects to, and may be reachable from, untrusted networks and the general internet.
  - The device supports multiple users, including concurrent users, and may store sensitive personal data and arbitrary data types.
  - Device misconfiguration by end users may lead to insecure operation.
  - Users are likely to physically interact with the device on a regular basis, so the device should protect against malicious peripherals.
  - Physical access to the device is likely to be limited only to trusted users, so tamper-resistant mitigations may not be needed – and may be counter-indicated if end-users are anticipated to perform maintenance tasks.
- Derived Risk Tolerance: LOW (2)

## 6.2.10 SP-PC-2 :: RT-????

Description: An enterprise workstation in a fixed and generally safe location

| Use Case | NUS R | CUS R | DAT A | SEN S | PHY S | LOS S | HW MD | SW MD | DVC S | TNE T | FNE T | CON F | TOTAL |
|----------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|
| UC-PC-2  | 1     | 2     | 2     | 1     | 0     | 0     | 2     | 2     | 1     | 2     | 1     | 1     | 14    |

- Risk Factor Score: –
- Risk Analysis
  - ...
- Derived Risk Tolerance: — (-)

## 6.2.11 SP-LA-1 :: RT-???

Description: A personal laptop

| Use Case | NUS R | CUS R | DAT A | SEN S | PHY S | LOS S | HW MD | SW MD | DVC S | TNE T | FNE T | CON F | TOTAL |
|----------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|
| UC-LA-1  | 1     | 2     | 2     | 1     | 1     | 1     | 1     | 2     | 2     | 2     | 2     | 2     | 19    |

- Risk Factor Score: –
- Risk Analysis
  - ...

- Derived Risk Tolerance: — (-)

## 6.2.12 SP-LA-2 :: RT-???

Description: Enterprise laptop

| Use Case | NUS R | CUS R | DAT A | SEN S | PHY S | LOS S | HW MD | SW MD | DVC S | TNE T | FNE T | CON F | TOTAL |
|----------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|
| UC-LA-2  | 1     | 2     | 2     | 1     | 1     | 1     | 1     | 2     | 2     | 2     | 2     | 1     | 18    |

- Risk Factor Score: –

- Risk Analysis

- ...

- Derived Risk Tolerance: — (-)

## 6.2.13 SP-PS-1 :: RT-???

Description: Personal server

| Use Case | NUS R | CUS R | DAT A | SEN S | PHY S | LOS S | HW MD | SW MD | DVC S | TNE T | FNE T | CON F | TOTAL |
|----------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|
|----------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|

- Risk Factor Score: –

- Risk Analysis

- ...

- Derived Risk Tolerance: — (-)

## 6.2.14 SP-SE-1 :: RT-???

Description: An enterprise server in a datacenter with no user accounts

| Use Case | NUS R | CUS R | DAT A | SEN S | PHY S | LOS S | HW MD | SW MD | DVC S | TNE T | FNE T | CON F | TOTAL |
|----------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|
| UC-SE-1  | 0     | 0     | 2     | 0     | 0     | 0     | 1     | 2     | 1     | 1     | 1     | 0     | 9     |

- Risk Factor Score: –

- Risk Analysis

- ...

- Derived Risk Tolerance: — (-)

## 6.2.15 SP-SE-2 :: RT-???

Description: An enterprise server in a datacenter with only trusted user accounts

| Use Case | NUS R | CUS R | DAT A | SEN S | PHY S | LOS S | HW MD | SW MD | DVC S | TNE T | FNE T | CON F | TOTAL |
|----------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|
| UC-SE-2  | 1     | 1     | 2     | 0     | 0     | 0     | 1     | 2     | 1     | 1     | 1     | 0     | 11    |

- 1505 • Risk Factor Score: –
- 1506 • Risk Analysis
- 1507     ○ ...
- 1508 • Derived Risk Tolerance: — (-)

## 1509 6.2.16 SP-SE-3 :: RT-???

1510 Description: An enterprise server in a datacenter hosting many untrusted user accounts

| Use Case | NUS R | CUS R | DAT A | SEN S | PHY S | LOS S | HW MD | SW MD | DVC S | TNE T | FNE T | CON F | TOTAL |
|----------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|
| UC-SE-3  | 2     | 2     | 2     | 0     | 0     | 0     | 1     | 2     | 1     | 1     | 1     | 0     | 13    |

- 1511 • Risk Factor Score: –
- 1512 • Risk Analysis
- 1513     ○ ...
- 1514 • Derived Risk Tolerance: — (-)

## 1515 6.2.17 SP-IF-1 :: RT-???

1516 Description: Internet infrastructure on private network

| Use Case | NUS R | CUS R | DAT A | SEN S | PHY S | LOS S | HW MD | SW MD | DVC S | TNE T | FNE T | CON F | TOTAL |
|----------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|
| UC-IF-1  | 0     | 0     | 1     | 0     | 0     | 0     | 1     | 0     | 0     | 1     | 0     | 2     | 5     |

- 1517 • Risk Factor Score: –
- 1518 • Risk Analysis
- 1519     ○ ...
- 1520 • Derived Risk Tolerance: — (-)

## 1521 6.2.18 SP-IF-2 :: RT-???

1522 Description: Internet infrastructure on filtered network

| Use Case | NUS R | CUS R | DAT A | SEN S | PHY S | LOS S | HW MD | SW MD | DVC S | TNE T | FNE T | CON F | TOTAL |
|----------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|
| UC-IF-2  | 0     | 0     | 1     | 0     | 0     | 0     | 1     | 0     | 0     | 2     | 1     | 1     | 5     |

- 1523 • Risk Factor Score: –
- 1524 • Risk Analysis
- 1525     ○ ...
- 1526 • Derived Risk Tolerance: — (-)

## 6.2.19 SP-IF-3 :: RT-???

Description: Internet infrastructure on open internet

| Use Case | NUS R | CUS R | DAT A | SEN S | PHY S | LOS S | HW MD | SW MD | DVC S | TNE T | FNE T | CON F | TOTAL |
|----------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|
| UC-IF-3  | 0     | 0     | 1     | 0     | 0     | 0     | 1     | 0     | 0     | 3     | 2     | 1     | 8     |

- Risk Factor Score: –
- Risk Analysis
  - ...
- Derived Risk Tolerance: — (-)

## 6.2.20 SP-FI-1 :: RT-???

Description: Firewall for personal network

| Use Case | NUS R | CUS R | DAT A | SEN S | PHY S | LOS S | HW MD | SW MD | DVC S | TNE T | FNE T | CON F | TOTAL |
|----------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|
| UC-FI-1  | 0     | 0     | 1     | 0     | 0     | 0     | 1     | 0     | 0     | 3     | 1     | 2     | 8     |

- Risk Factor Score: –
- Risk Analysis
  - ...
- Derived Risk Tolerance: — (-)

## 6.2.21 SP-FI-2 :: RT-???

Description: Firewall for enterprise network

| Use Case | NUS R | CUS R | DAT A | SEN S | PHY S | LOS S | HW MD | SW MD | DVC S | TNE T | FNE T | CON F | TOTAL |
|----------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|-------|
| UC-FI-2  | 0     | 0     | 1     | 0     | 0     | 0     | 1     | 0     | 0     | 3     | 1     | 1     | 7     |

- Risk Factor Score: –
- Risk Analysis
  - ...
- Derived Risk Tolerance: — (-)

## 6.3 Mapping of Security Profile to Risk Tolerance

## 6.4 Mapping of Security Profile to Risk Mitigation

---

1547 **Annex A (informative): Relationship between the present**  
1548 **document and any related ETSI standards (if any)**

1549 *List any related ETSI standards and how they interact with the present document.*

## Annex A (informative): Mapping between the present document and CRA requirements

Table mapping technical security requirements from Section 5 of the present document to essential cybersecurity requirements in Annex I of the CRA. The purpose of this is to help identify missing technical security requirements.

| CRA requirement                                 | Technical security requirements(s) |
|-------------------------------------------------|------------------------------------|
| No known exploitable vulnerabilities            |                                    |
| Secure design, development, production          |                                    |
| Secure by default configuration                 |                                    |
| Secure updates                                  |                                    |
| Authentication and access control mechanisms    |                                    |
| Confidentiality protection                      |                                    |
| Integrity protection for data and configuration |                                    |
| Data minimization                               |                                    |
| Availability protection                         |                                    |
| Minimize impact on other devices or services    |                                    |
| Limit attack surface                            |                                    |
| Exploit mitigation by limiting incident impact  |                                    |
| Logging and monitoring mechanisms               |                                    |
| Secure deletion and data transfer               |                                    |

---

1555 **Annex B (informative): Relationship between the present**  
1556 **document and any related ETSI standards (if any)**

1557 List any related ETSI standards and how they interact with the present document.

---

## 1558 Annex C (informative): Risk identification and assessment 1559 methodology

### 1560 C.1 Assets

#### 1561 C.1.1 Data

1562 What data is stored on the product?

- 1563 • Logs
- 1564 • Secrets/credentials
- 1565 • Executables (kernel, apps, libraries, etc.)
- 1566 • Configuration
- 1567 • Firmware images
- 1568 • User data

#### 1569 C.1.2 Product functions

1570 See the functions in Section 4.7.

### 1571 C.2 Threats

1572 Based on the assets, what are the threats during:

- 1573 • Use for intended purpose or reasonably foreseeable use
- 1574 • When integrated into another product

1575 Example threats can be found in the same documents suggested in the section on  
1576 security requirements.

1577 From NIAP PP for OS:



1578 T.NETWORK ATTACK: An attacker is positioned on a communications channel or elsewhere on the network  
 1579 infrastructure. Attackers may engage in communications with applications and services running on or part of the OS  
 1580 with the intent of compromise. Engagement may consist of altering existing legitimate communications.

1581 T.NETWORK EAVESDROP: An attacker is positioned on a communications channel or elsewhere on the network  
 1582 infrastructure. Attackers may monitor and gain access to data exchanged between applications and services that are  
 1583 running on or part of the OS.

1584 T.LOCAL ATTACK: An attacker may compromise applications running on the OS. The compromised application may  
 1585 provide maliciously formatted input to the OS through a variety of channels including unprivileged system calls and  
 1586 messaging via the file system.

1587 T.LIMITED PHYSICAL ACCESS An attacker may attempt to access data on the OS while having a limited amount of  
 1588 time with the physical device.

1589 From BSI Common Criteria Protection Profile:

1590 T.ACCESS.TSFDATA: A threat agent might read or modify TSF data without the necessary authorization when the  
 1591 data is stored or transmitted.

1592 T.ACCESS.USERDATA: A threat agent might gain access to user data stored, processed or transmitted by the TOE  
 1593 without being appropriately authorized according to the TOE security policy.

1594 T.ACCESS.TSFFUNC: A threat agent might use or modify functionality of the TSF without the necessary privilege to  
 1595 grant itself or others unauthorized access to TSF data or user data.

1596 T.ACCESS.COMM: A threat agent might access a communication channel that establishes a trust relationship between  
 1597 the TOE and another remote trusted IT system or masquerade as another remote trusted IT system.

1598 T.RESTRICT.NETTRAFFIC: A threat agent might get access to information or transmit information to other recipients  
 1599 via network communication channels without authorization for this communication attempt by the information flow  
 1600 control policy.

1601 T.IA.MASQUERADE: A threat agent might masquerade as an authorized entity including the TOE itself or a part of  
 1602 the TOE in order to gain unauthorized access to user data, TSF data, or TOE resources.

1603 T.IA.USER: A threat agent might gain access to user data, TSF data or TOE resources with the exception of public  
 1604 objects without being identified and authenticated

1605 From [MITRE EMB3D](#):

1606 Hardware: \* [TID-101](#): Power Consumption Analysis Side Channel \* [TID-102](#): Electromagnetic Analysis Side Channel  
 1607 \* [TID-103](#): Microarchitectural Side Channels \* [TID-105](#): Hardware Fault Injection – Control Flow Modification \* [TID-](#)  
 1608 [106](#): Data Bus Interception \* [TID-107](#): Unauthorized Direct Memory Access (DMA) \* [TID-108](#): ROM/NVRAM Data  
 1609 Extraction or Modification \* [TID-109](#): RAM Chip Contents Readout \* [TID-110](#): Hardware Fault Injection – Data  
 1610 Manipulation \* [TID-111](#): Untrusted External Storage \* [TID-113](#): Unverified Peripheral Firmware Loaded \* [TID-114](#):  
 1611 Peripheral Data Bus Interception \* [TID-115](#): Firmware/Data Extraction via Hardware Interface \* [TID-116](#): Latent  
 1612 Privileged Access Port \* [TID-118](#): Weak Peripheral Port Electrical Damage Protection \* [TID-119](#): Latent Hardware  
 1613 Debug Port Allows Memory/Code Manipulation

1614 System Software: \* [TID-201](#): Inadequate Bootloader Protection and Verification \* [TID-202](#): Exploitable System  
 1615 Network Stack Component \* [TID-203](#): Malicious OS Kernel Driver/Module Installable \* [TID-204](#): Untrusted Programs  
 1616 Can Access Privileged OS Functions \* [TID-205](#): Existing OS Tools Maliciously Used for Device Manipulation \* [TID-](#)  
 1617 [206](#): Memory Management Protections Subverted \* [TID-207](#): Container Escape \* [TID-208](#): Virtual Machine Escape \*  
 1618 [TID-209](#): Host Can Manipulate Guest Virtual Machines \* [TID-210](#): Device Vulnerabilities Unpatchable \* [TID-211](#):  
 1619 Device Allows Unauthenticated Firmware Installation \* [TID-212](#): FW/SW Update Integrity Shared Secrets Extraction \*  
 1620 [TID-213](#): Faulty FW/SW Update Integrity Verification \* [TID-214](#): Secrets Extracted from Device Root of Trust \* [TID-](#)  
 1621 [215](#): Unencrypted SW/FW Updates \* [TID-216](#): Firmware Update Rollbacks Allowed \* [TID-217](#): Remotely Initiated  
 1622 Updates Can Cause DoS \* [TID-218](#): Operating System Susceptible to Rootkit \* [TID-219](#): OS/Kernel Privilege  
 1623 Escalation \* [TID-220](#): Unpatchable Hardware Root of Trust \* [TID-221](#): Authentication Bypass By Message Replay \*  
 1624 [TID-222](#): Critical System Service May Be Disabled \* [TID-223](#): System Susceptible to RAM Scraping \* [TID-224](#):  
 1625 Excessive Access via Software Diagnostic Features \* [TID-225](#): Logs can be manipulated on the device \* [TID-226](#):  
 1626 Device leaks security information in logs

1627 Application Software: \* [TID-301](#): Applications Binaries Modified \* [TID-302](#): Install Untrusted Application \* [TID-303](#):  
 1628 Excessive Trust in Offboard Management/IDE Software \* [TID-304](#): Manipulate Runtime Environment \* [TID-305](#):  
 1629 Program Executes Dangerous System Calls \* [TID-306](#): Sandboxed Environments Escaped \* [TID-307](#): Device Code

1630 Representations Inconsistent \* [TID-308](#): Code Overwritten to Avoid Detection \* [TID-309](#): Device Exploits Engineering  
 1631 Workstation \* [TID-310](#): Remotely Accessible Unauthenticated Services \* [TID-311](#): Default Credentials \* [TID-312](#):  
 1632 Credential Change Mechanism Can Be Abused \* [TID-313](#): Unauthenticated Session Changes Credential \* [TID-314](#):  
 1633 Passwords Can Be Guessed Using Brute-Force Attempts \* [TID-315](#): Password Retrieval Mechanism Abused \* [TID-](#)  
 1634 [316](#): Incorrect Certificate Verification Allows Authentication Bypass \* [TID-317](#): Predictable Cryptographic Key \* [TID-](#)  
 1635 [318](#): Insecure Cryptographic Implementation \* [TID-319](#): Cross Site Scripting (XSS) \* [TID-320](#): SQL Injection \* [TID-](#)  
 1636 [321](#): HTTP Application Session Hijacking \* [TID-322](#): Cross Site Request Forgery (CSRF) \* [TID-323](#): Path Traversal \*  
 1637 [TID-324](#): HTTP Direct Object Reference \* [TID-325](#): HTTP Injection/Response Splitting \* [TID-326](#): Insecure  
 1638 Deserialization \* [TID-327](#): Out of Bounds Memory Access \* [TID-328](#): Hardcoded Credentials \* [TID-329](#): Improper  
 1639 Password Storage \* [TID-330](#): Cryptographic Timing Side-Channel

1640 Networking: \* [TID-401](#): Undocumented Protocol Features \* [TID-404](#): Remotely Triggerable Deadlock/DoS \* [TID-](#)  
 1641 [405](#): Network Stack Resource Exhaustion \* [TID-406](#): Unauthorized Messages or Connections \* [TID-407](#): Missing  
 1642 Message Replay Protection \* [TID-408](#): Unencrypted Sensitive Data Communication \* [TID-410](#): Cryptographic  
 1643 Protocol Side Channel \* [TID-411](#): Weak/Insecure Cryptographic Protocol \* [TID-412](#): Network Routing Capability  
 1644 Abuse

1645 Baseband OS running on the baseband processor on most smartphones is a special case: Usually it has DMA write  
 1646 access to the user-facing OS (Android), on the application processor and the user-facing OS can't protect itself against  
 1647 that.

1648 Anything can run with elevated privileges if root runs it... is there a mitigation here?

1649 FIXME list more threats (e.g. other sources)

## 1650 C.3 Assumptions

1651 List assumptions that are relevant to the risk analysis for these threats. Everything is  
 1652 hackable if you try hard enough. What kinds of threats are in and out of scope?  
 1653 What are you assuming is the sophistication of attack? Relate to use cases.

- 1654 • Proper platform
    - 1655 ○ **Rationale:** An operating system requires a trustworthy platform to perform its functions.
  - 1656 • Proper administrator
    - 1657 ○ **Rationale:** An operating system requires effective administration to perform its functions.
  - 1658 • Proper user
- 1659 FIXME where does trusted/untrusted hardware devices go? External/internal  
 1660 interfaces, what can the operating system protect against, what can be accessed with  
 1661 a limited time access by attacker?
- 1662 • Not being attacked by a state actor
  - 1663 • Not using sophisticated or expensive hardware snooping techniques
  - 1664 • No secret hardware backdoors

1665 From NIAP PP for OS:

1666 A.PLATFORM: The OS relies upon a trustworthy computing platform for its execution. This underlying platform is out  
 1667 of scope of this PP.

1668 A.PROPER USER: The user of the OS is not willfully negligent or hostile, and uses the software in compliance with  
 1669 the applied enterprise security policy. At the same time, malicious software could act as the user, so requirements which  
 1670 confine malicious subjects are still in scope.

1671 A.PROPER ADMIN: The administrator of the OS is not careless, willfully negligent or hostile, and administers the OS  
 1672 within compliance of the applied enterprise security policy.

1673 FIXME list more assumptions

## C.4 Risk assessments of threats

For each threat identified above, use likelihood and magnitude of the threat to assess its risk in the context of use cases. The results should be consistent with the mapping of use cases to security levels.

Guidance from latest PT1 draft:

An analysis in terms of likelihood and magnitude of a product's threats is required to be able to determine the product's risks.

NOTE 1 This document does not require a specific methodology for a cybersecurity risk analysis as long as the cybersecurity risk estimation is based on the likelihood of occurrence and magnitude of loss or disruption of cybersecurity risks. Thus, different approaches and models such as the fishbone model, event tree analysis or fault tree models can be used within the analysis of cybersecurity risks.

NOTE 2 A qualitative estimation of the cybersecurity risks can be performed using risk matrices that map qualitative categories of the likelihood of occurrence and qualitative categories of magnitude of loss or disruption to cybersecurity risk categories.

NOTE 3 A quantitative estimation of the cybersecurity risks can be performed using scoring systems that map qualitative categories of the likelihood of occurrence and qualitative categories of magnitude of loss or disruption to certain values.

---

## 1693 Annex D (informative): Risk evaluation guidance

### 1694 D.1 Mapping of risks to requirements

1695 Table mapping the identified risks to requirements

### 1696 D.2 Risks not treated by the requirements

1697 If any risks are not treated by the normative requirements, describe non-normative  
1698 suggestions to mitigate them.

### 1699 D.3 Risk acceptance criteria

1700 Describe how to decide if residual risks are tolerable.

### 1701 D.4 Residual risks

1702 Describe how to treat any residual risks, for example by documenting them or  
1703 informing the user.

## Annex E: Notes

**\*\*NOTE:** This section is a temporary storage place for notes, will be deleted.

FIXME include the relation graphic between verticals in the architecture overview to explain the outside relationship.

FIXME: Ensure the following cases present in most x86 computers are not lost, assign them to the scope of a vertical (may be ours, may be another vertical).

Special case UEFI updates triggered by the operating system: The update mechanism as provided by the firmware (UEFI capsule) is considered to be in the scope of the boot manager vertical, as is the cryptographic verification of such updates.

Special case Windows drivers delivered as part of UEFI and retrieved by Windows from UEFI during Windows installation (usually hardware enablement like storage and network drivers). FIXME: Look up the name of that mechanism.

Special case of Windows using calls into UEFI runtime services if no native Windows driver for a given peripheral (may even be the graphics card) exists. Does that make this specific UEFI driver part of the operating system?

Special case of System Management Mode (SMM) running in the background with privileges higher than the OS kernel and higher than the hypervisor (if any) and emulating hardware and/or monitoring CPU temperature, possibly forcing shutdown to prevent overheating.

Special case of verified/measured boot partially implemented outside the operating system and outside the CPU, e.g. delegated to the Intel CSME (separate x86/ARC CPU with JTAG access to the main CPU).

Special case configuration files? Not code in most cases, but substantial impact on the security configuration of the operating system.

### DRAFT ANNEX L - DO NOT CONSIDER THE CONTENT

The present document has been prepared under the Commission's standardisation request C(2025) 618 final to provide one voluntary means of conforming to the requirements of Regulation (EU) No 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act). Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

**NOTE:** The above paragraphs have to be repeated in the Foreword.

The annex shall have a table for a clear indication of correspondence between normative clauses of the standard and the legal requirements aimed to be covered.

**It should be evaluated - on the basis of the legal requirements supported and other information given in a harmonised standard - how detailed correspondence can be indicated between the normative elements of the harmonised standard and the legal requirements aimed to be covered. However, where this correspondence is expressed in too general terms, it could lead to a situation where the Commission cannot assess whether the Harmonised Standard satisfies the requirements, which it aims to cover, and subsequently publication of its references in the OJEU according to Article 10(6) of the Regulation is significantly delayed or is not possible at all.**

### EXAMPLE for a table:

Table: Table A.1: Relationship between the present document and the requirements of EU Regulation 2024/2847

1747 Harmonised Standard ETSI EN 304 6xx

| Requirement |             |                            |                                   | Requirement Conditionality |           |
|-------------|-------------|----------------------------|-----------------------------------|----------------------------|-----------|
| No          | Description | Requirements of Regulation | Clause(s) of the present document | Use case                   | Condition |
| 1           |             |                            |                                   |                            |           |
| 2           |             |                            |                                   |                            |           |
| 3           |             |                            |                                   |                            |           |
| ...         |             |                            |                                   |                            |           |

1748 **Key to columns:**

1749 **Requirement:**

1750 **No** A unique identifier for one row of the table which may be used to identify a requirement.

1751 **Description** A textual reference to the requirement.

1752 **Requirements of Regulation** Identification of article(s) defining the requirement in the Regulation.

1753 **Clause(s) of the present document** Identification of clause(s) defining the requirement in the present document unless  
1754 another document is referenced explicitly.

1755 **Requirement Conditionality:**

1756 **Use case** Indicates whether the requirement is unconditionally applicable (U) or is conditional upon the manufacturer's  
1757 claimed functionality of the equipment (C).

1758 **Condition** Explains the conditions when the requirement is or is not applicable for a requirement which is classified  
1759 "conditional".

1760 NOTE 1: The table cannot indicate direct relationship between the relevant legal  
1761 requirement and other standards or normative clauses contained in other standards.

1762 NOTE 2: The order of the first and the second columns can be changed.

1763 NOTE 3: The title of this column can be adapted on the basis of specific needs

1764 The annex shall have at least the following two warnings.

1765 A warning stating that presumption of conformity is effective only as long as the reference is maintained in the OJEU  
1766 by the Commission. The following URL-address [https://ec.europa.eu/growth/single-market/european-](https://ec.europa.eu/growth/single-market/european-standards/harmonised-standards_en)  
1767 [standards/harmonised-standards\\_en](https://ec.europa.eu/growth/single-market/european-standards/harmonised-standards_en) to consult the latest list of Harmonised Standards published in the OJEU should be  
1768 provided.

1769 Presumption of conformity stays valid only as long as a reference to the present document is maintained in the list  
1770 published in the Official Journal of the European Union. Users of the present document should consult frequently the  
1771 latest list published in the Official Journal of the European Union.

1772 A warning stating that those products or services which are within the scope of a relevant standard may be also subject  
1773 to other Union legislation.

1774 Other Union legislation may be applicable to the product(s) falling within the scope of the present document.

1775

---

## Annex <L+3> (informative): Bibliography

1776

<Publication>: “<Title>”.<Edition>. <Year>, <Issue designation>, <Page location>.

1777

## Annex <L+4> (informative): Change history

1778

The “Change history/Change request (history)” annex shall be included in every revised or amended harmonised standard and shall contain information concerning significant changes that have been introduced by it. It shall be presented as a table.

1779

1780

| Date         | Version | Information about changes              |
|--------------|---------|----------------------------------------|
| <Month year> | <#>     | <Changes made are listed in this cell> |
|              |         |                                        |
|              |         |                                        |
|              |         |                                        |



1781

---

## History

1782

The following table will automatically be filled in by the ETSI Secretariat.

| Document History |      |           |
|------------------|------|-----------|
| Version          | Date | Milestone |
|                  | <#>  |           |

1783